

Rastro: extensão Firefox para detecção de rastreadores

Avaliação Intermediária de Cibersegurança, Insper. Mateus Porto Pereira de Paiva, matrícula 23620308.

Repositório: github.com/Mateus-PortoPP/cyber_PI

1. A extensão

A Rastro (Manifest V2) mostra, por aba: domínios de terceira parte (eTLD+1 diferente do da página, via `webRequest`); cookies injetados, por `Set-Cookie` e `cookies.onChanged`, separados em primeira ou terceira parte e sessão ou persistente; armazenamento HTML5 por `frame`; canvases fingerprint, interceptando `toDataURL`, `toBlob`, `getImageData`, `convertToBlob` e `readPixels` (suspeita: leitura de pelo menos 16×16 de um canvas com texto ou WebGL); bounce tracking, por `redirect HTTP`, `client_redirect` ou saída em menos de 10 s sem interação após um link; cookie sync, por um mesmo valor com cara de ID enviado a dois ou mais terceiros; parâmetros de rastreo na URL; e a nota da seção 5. Instalação no `README.md`.

2. Método

- Firefox 156 no macOS, proteção contra rastreamento no nível Padrão, extensão temporária carregada antes de abrir cada página. Outras abas abertas nos prints não compartilham domínio com a página testada, então não interferem na atribuição de cookies, que é por domínio.
- Páginas que gravam dados foram testadas com os dados do site limpos (cadeado, "Limpar cookies e dados do site"). Exceção: a Wikipédia, em que o HAR mostra que a limpeza não foi feita (seção 4.1).
- uBlock Origin desligado em todos os testes do plugin (ícone cinza nos prints); ligado só para os prints `*_ublock*.png`. Bloqueio do uBlock aparece na aba Rede como "Bloqueado por uBlock Origin"; `NS_ERROR_*` é falha da própria requisição.
- Validação com a aba Rede do DevTools e `browser.cookies.getAll`; falhas das páginas de teste foram reproduzidas com a extensão removida.

3. Entregável 2: DuckDuckGo Privacy Test Pages

Domínios de teste do `privacy-test-pages.site`: `bad.third-party.site` (rastreador que o DDG bloqueia), `broken.third-party.site` (rastreador não bloqueado) e `good.third-party.site` (terceiro que não rastreia). Os três têm o mesmo eTLD+1, `third-party.site`, o que explica parte das divergências. Quando a página não reporta resultado, o "esperado" é o comportamento descrito nela.

3.1 Tabela de resultados

Teste	Esperado (reportado pela página)	Resultado do plugin	Explicação da divergência
Tracker Reporting: 1 major tracker loaded via script Figura 1; apêndice: figura 30	1 rastreador: <code><script src="//doubleclick.net/tracker.js"></code>	<code>doubleclick.net</code> , 1 requisição, <code>script</code> . Nota 98.	Detecção igual. Na aba Rede (figura 30) a requisição sai e volta como <code>html, 0 B</code> , <code>NS_ERROR_CORRUPTED_CONTENT</code> : o domínio real não serve JavaScript nesse caminho. A proteção do Firefox no nível Padrão não bloqueia o <code>script</code> . O plugin conta a tentativa de conexão, não se o <code>script</code> rodou.
Tracker Reporting: 1 major tracker with surrogate Figura 2	1 rastreador (<code>doubleclick.net</code>), que o DDG trocaria por um script inofensivo	<code>doubleclick.net</code> , 1 requisição, <code>script</code> . Nota 98.	O plugin não injeta surrogate, só observa; registra a requisição original.
Tracker Reporting: 1 major tracker loaded via img Figura 3	1 rastreador via <code></code>	<code>facebook.com</code> , 1 requisição, <code>image</code> , 1 cookie de terceira parte persistente. Nota 94 (-2, -3, -1).	Sem divergência. O plugin mostra também o cookie de terceira parte que a resposta do pixel gravou.
Tracker Reporting: Image loaded via document fragment Figura 4	1 rastreador (<code>facebook.com</code>) criado via document fragment	<code>facebook.com</code> , 1 requisição, <code>image</code> . Nota 98.	Sem divergência. A forma de inserir o elemento no DOM não muda a requisição.

Tracker Reporting: document fragment [Delay 5s] Figura 5	Mesmo rastreador, 5 s depois do carregamento	facebook.com, 1 requisição, image. Nota 98.	Sem divergência. O listener de rede fica ativo a vida inteira da página.
Tracker Reporting: 1 major tracker loaded via fetch Figura 6	"Tracker loaded" (fetch para facebook.com)	facebook.com, 1 requisição, xmlhttprequest. Nota 98.	Sem divergência. O Firefox classifica fetch() como xmlhttprequest no webRequest.
Tracker Reporting: via fetch [Delay 5s] Figura 7	"Tracker loaded", 5 s depois do carregamento	facebook.com, 1 requisição, xmlhttprequest. Nota 98.	Sem divergência.
Storage blocking Figura 8; apêndice: figuras 31, 32	"Stored random number ... using 23 storage mechanisms (1 failed)"; a falha é o WebSQL (openDatabase is not defined)	2 domínios de terceira parte; 24 cookies gravados (17 de terceira parte, 7 de primeira, todos persistentes); 3 origens de terceira parte com armazenamento em 4 frames. Nota 56 (-4, -20, -10, -10). Execução 443 (figuras 31 e 32): mesma contagem; cookies em broken. e good.third-party.site e convert.ad-company.site; só 9 Set-Cookie recebidos, porque a maioria é gravada por document.cookie.	(1) WebSQL: o Firefox nunca implementou a API. (2) IndexedDB vazio no iframe convert.ad-company.site: ele não carrega /helpers/idb-wrapper.js (HTTP 404, conferido com curl) e a página mostra "DB is not defined". (3) tptdata e tpsdata contam como primeira parte (figura 32) porque scripts de broken. e good.third-party.site os gravam via document.cookie no contexto da página, e o cookie recebe o domínio dela.
Fingerprinting canvas verification Figura 9; apêndice: figura 33	Tabela pass/fail; na seção "resistance" (figura 9), 2 fail: os testes esperam ruído anti-fingerprint nos pixels	Canvas fingerprint detectado: getImageData 122 leituras, 102 suspeitas; toDataURL 3 leituras, 0 suspeitas. 1 terceiro (cdnjs.cloudflare.com, script). Nota 78.	Os fail são iguais com a extensão removida. O teste espera que o navegador adicione ruído aleatório aos pixels, o que o Firefox no modo Padrão não faz e o plugin, só observador, também não. Sem ruído, a leitura do canvas é estável, e é isso que torna o fingerprint possível.
Fingerprinting (Start the test) Figura 10; apêndice: figura 34	"Collected 124 datapoints (14 failed)", com 4 testes de canvas: canvas-2d-toDataURL, canvas-2d-imagedata, canvas-2d-offscreen-toDataURL, canvas-webgl	toDataURL 4 leituras, 4 suspeitas; getImageData 1 e 1. Canvas detectado (-20). Nenhum terceiro, nenhum cookie. Nota 80.	Os 4 testes de canvas foram detectados, inclusive o do OffscreenCanvas, que desenha num canvas e lê de outro. Os outros 120 datapoints (navigator, screen, WebGL, cabeçalhos) estão fora do escopo pedido, canvas.
Tracker Blocking Figura 11	Pede bad.third-party.site na lista de bloqueio e espera 23 requisições bloqueadas. Resultado: 22 carregaram, só o websocket falhou	1 domínio de terceira parte, nenhum cookie, nenhum armazenamento de terceiros. Nota 98.	O plugin não usa webRequestBlocking e não cancela nada, por isso as 22 carregaram. O websocket falhou por conta própria.
Storage partitioning Figura 12	"Retrieved data from 21 storage mechanisms". Os 3 mecanismos de cookie: fail (dado gravado num contexto foi lido no outro). Os 16 de armazenamento e cache e o HSTS: pass. WebSQL e Prefetch Cache: unsupported.	1 terceiro (privacy-test-pages.site, 3 imagens, -2); 3 cookies persistentes de primeira parte (-3); 3 frames do próprio site com armazenamento. Nota 95.	A página grava num contexto de topo e lê de outro. O plugin reinicia o relatório a cada navegação de topo (background.js, main_frame), então mostra só a última página e não correlaciona o que um site gravou com o que outro leu, que é o que o teste mede. Os fail são comportamento do Firefox, não do plugin.

Bounce tracking (4 links) Figuras 13, 14	Cada link passa por <code>bad.third-party.site/.../bounce.html</code> , que grava um ID (cookie e localStorage) e redireciona por <code>location.href</code> passando o ID na URL	<code>good.third-party.site</code> : nenhum bounce. <code>first-party.site</code> , <code>privacy-test-pages.site</code> , <code>publisher-company.site</code> : bounce por <code>bad.third-party.site</code> . Figura 13: "saída automática em poucos segundos, ficou 0.4 s, gravou 0 cookie(s)", destino ? <code>bounceUIDlocalStorage=83&bounceUIDcookie=83&isNew=</code> . Critério 6: -15.	(1) <code>good.third-party.site</code> não é acusado porque intermediário e destino têm o mesmo eTLD+1. (2) O Firefox não marcou <code>client_redirect</code> (a página responde 200 e redireciona por script); a detecção veio da regra de saída em menos de 10 s sem interação. (3) "0 cookie(s)" e <code>isNew=</code> vazio: o ID 83 já existia no intermediário, porque outro link já tinha passado por lá; o bounce é detectado mesmo assim, porque a regra olha a navegação. (4) O ID do DDG (1 a 101) é curto para a regra de cookie sync (mínimo 8 caracteres).
Query parameters (4 links) Figura 15	Quatro links de <code>privacy-test-pages.site</code> para <code>good.third-party.site/.../query.html</code> : com <code>utm_source</code> ; com <code>utm_source</code> e <code>utm_medium</code> ; com <code>fbclid</code> e <code>fb_source</code> (e o parâmetro comum <code>u=14</code>); e um só com parâmetros comuns. Um navegador com proteção removeria os de rastreo	Detectados, na ordem: <code>utm_source</code> ; <code>utm_source</code> , <code>utm_medium</code> ; <code>fbclid</code> , <code>fb_source</code> (figura 15, com <code>u=14</code> ignorado); nenhum. <code>q</code> , <code>u</code> e <code>id</code> nunca foram acusados.	O "Results" da página mostra que os parâmetros chegaram: o Firefox no nível Padrão não os remove. O plugin não reescreve URL, só detecta e desconta.

3.2 Prints do plugin em execução

Cada linha da tabela 3.1 indica as figuras correspondentes; os prints complementares estão no Apêndice A.

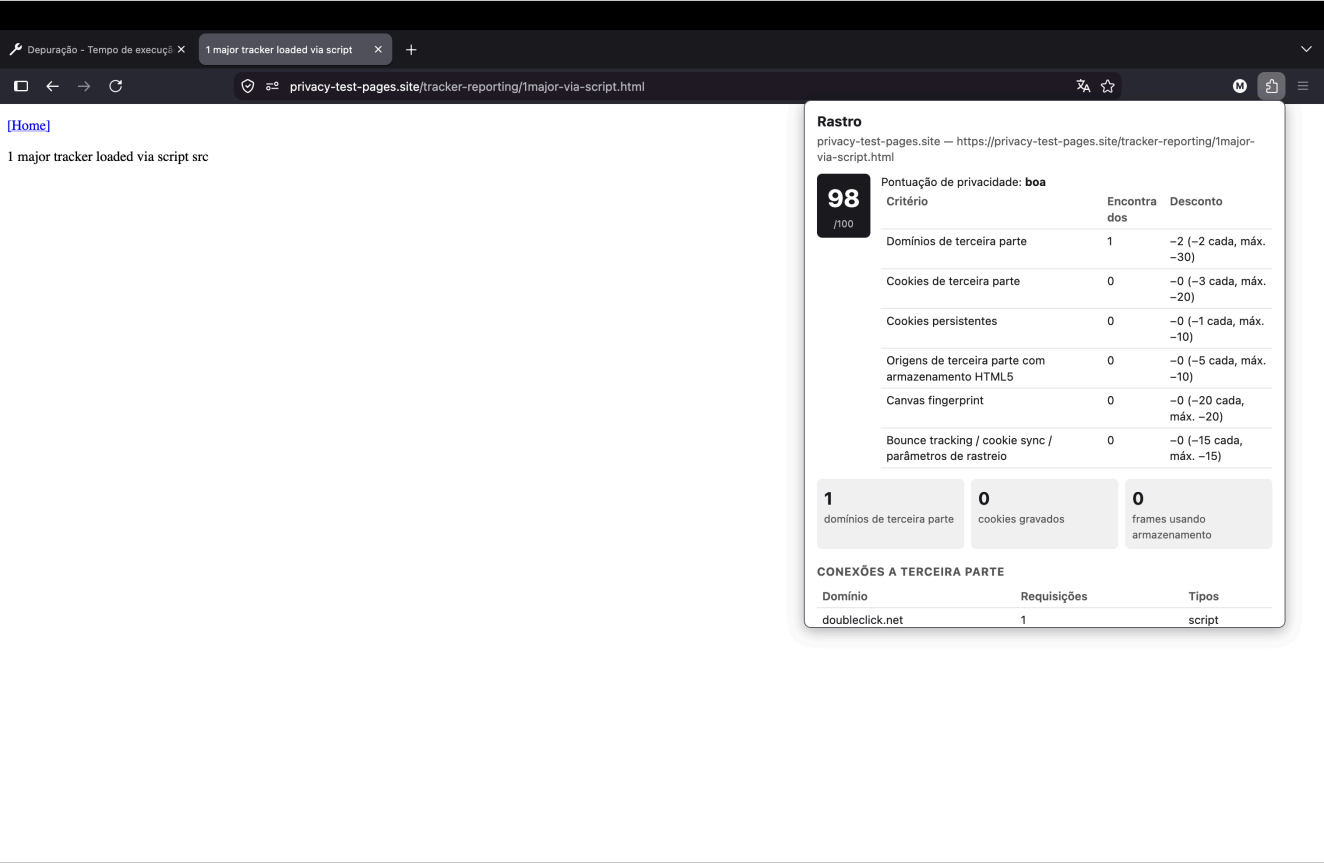


Figura 1. Tracker Reporting, via script

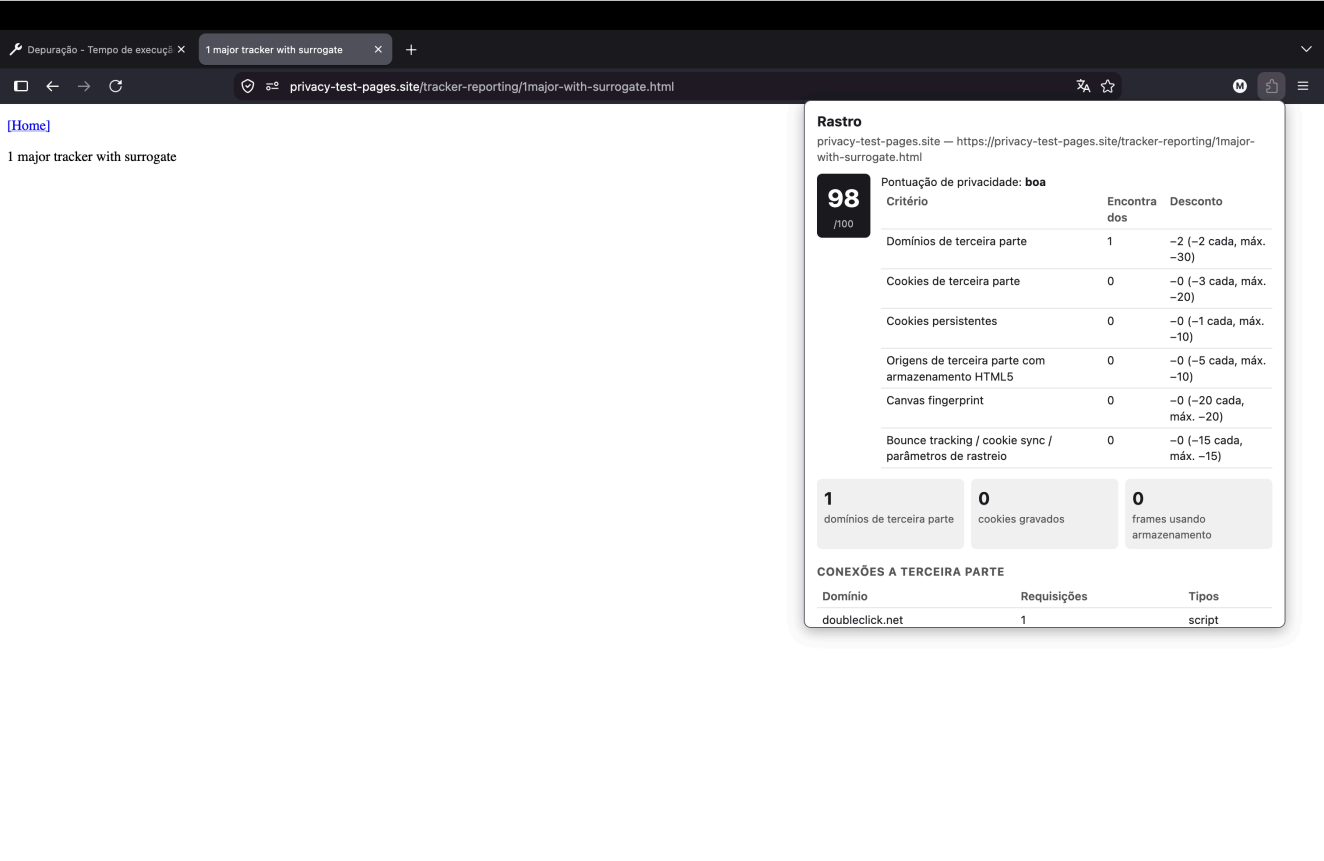


Figura 2. Tracker Reporting, with surrogate

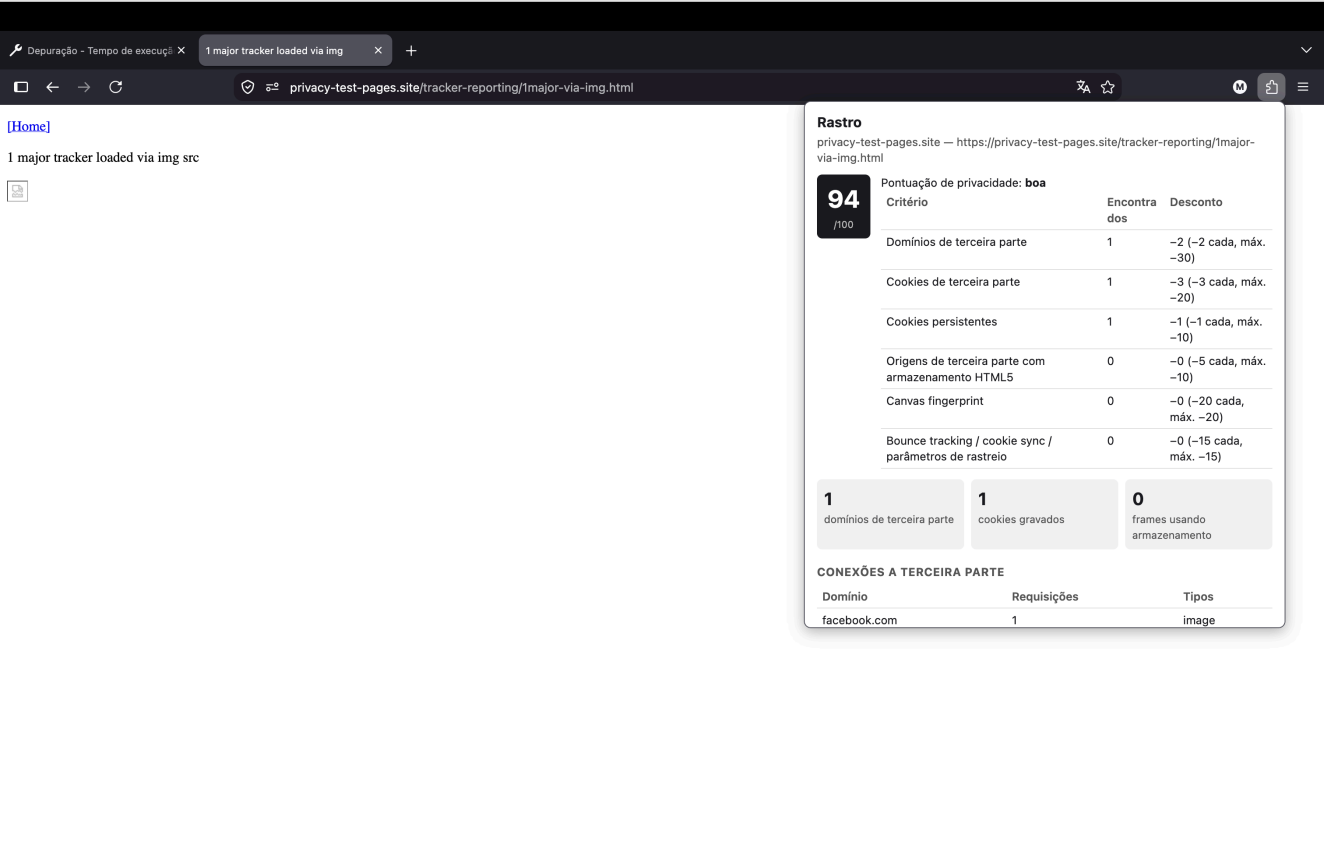


Figura 3. Tracker Reporting, via img

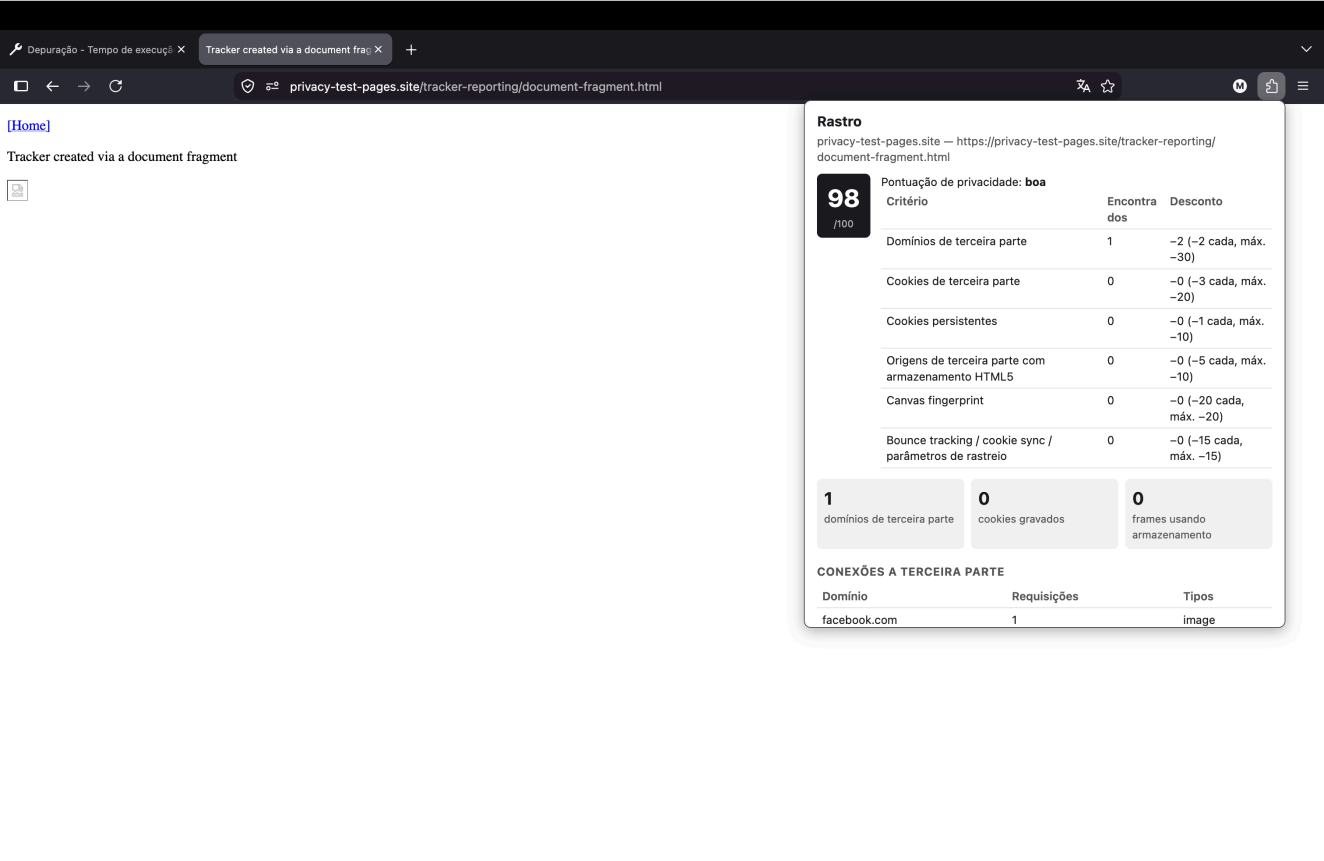


Figura 4. Tracker Reporting, document fragment

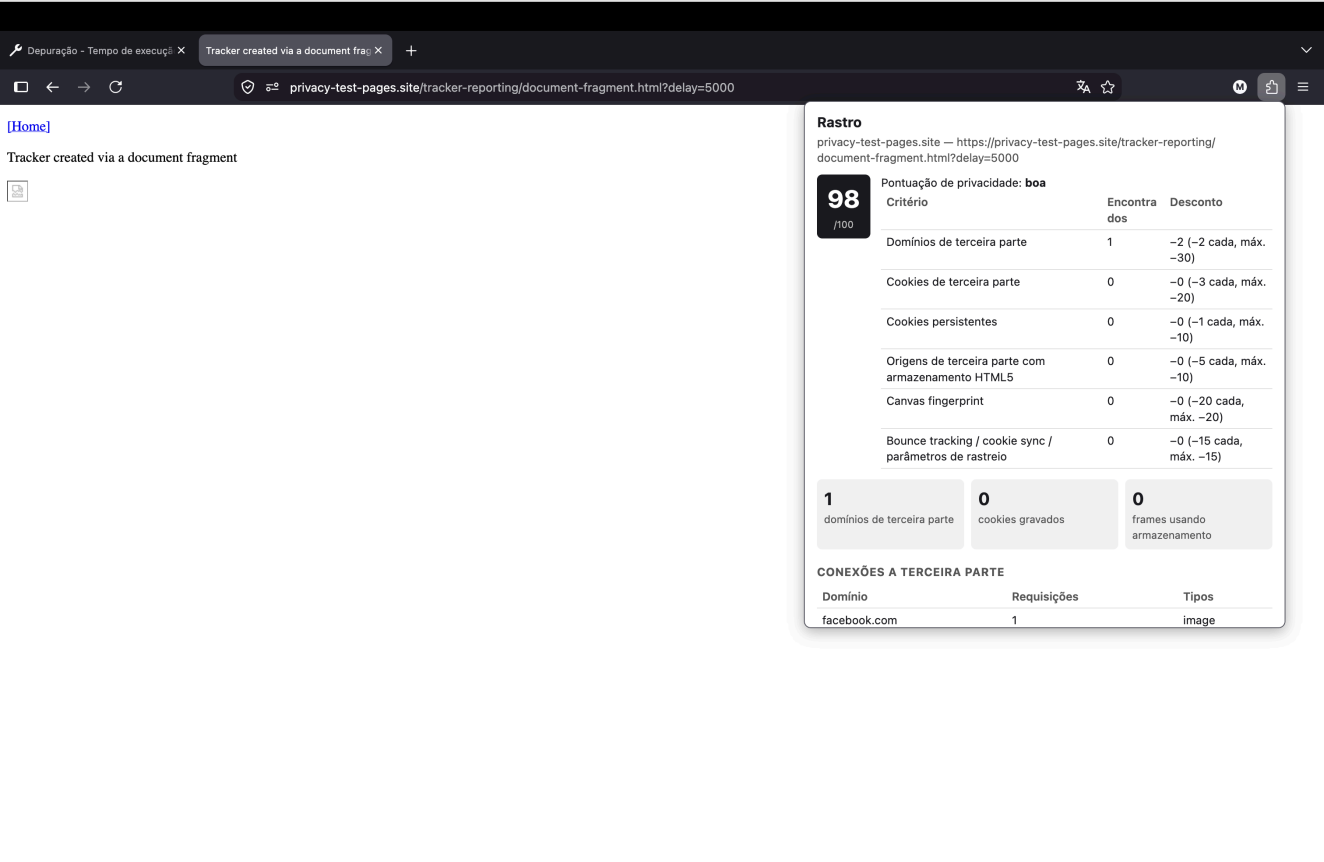


Figura 5. Tracker Reporting, document fragment com delay de 5 s

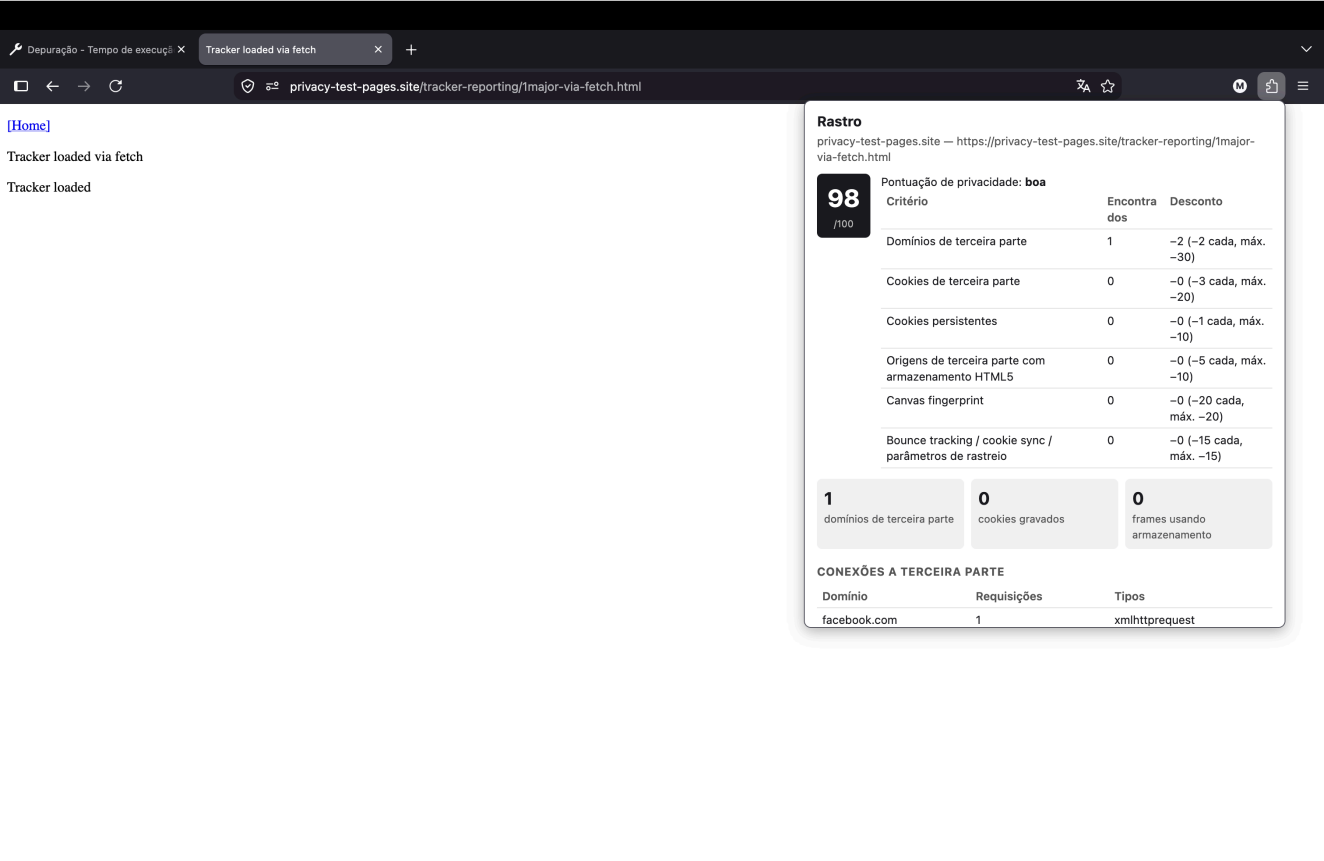


Figura 6. Tracker Reporting, via fetch

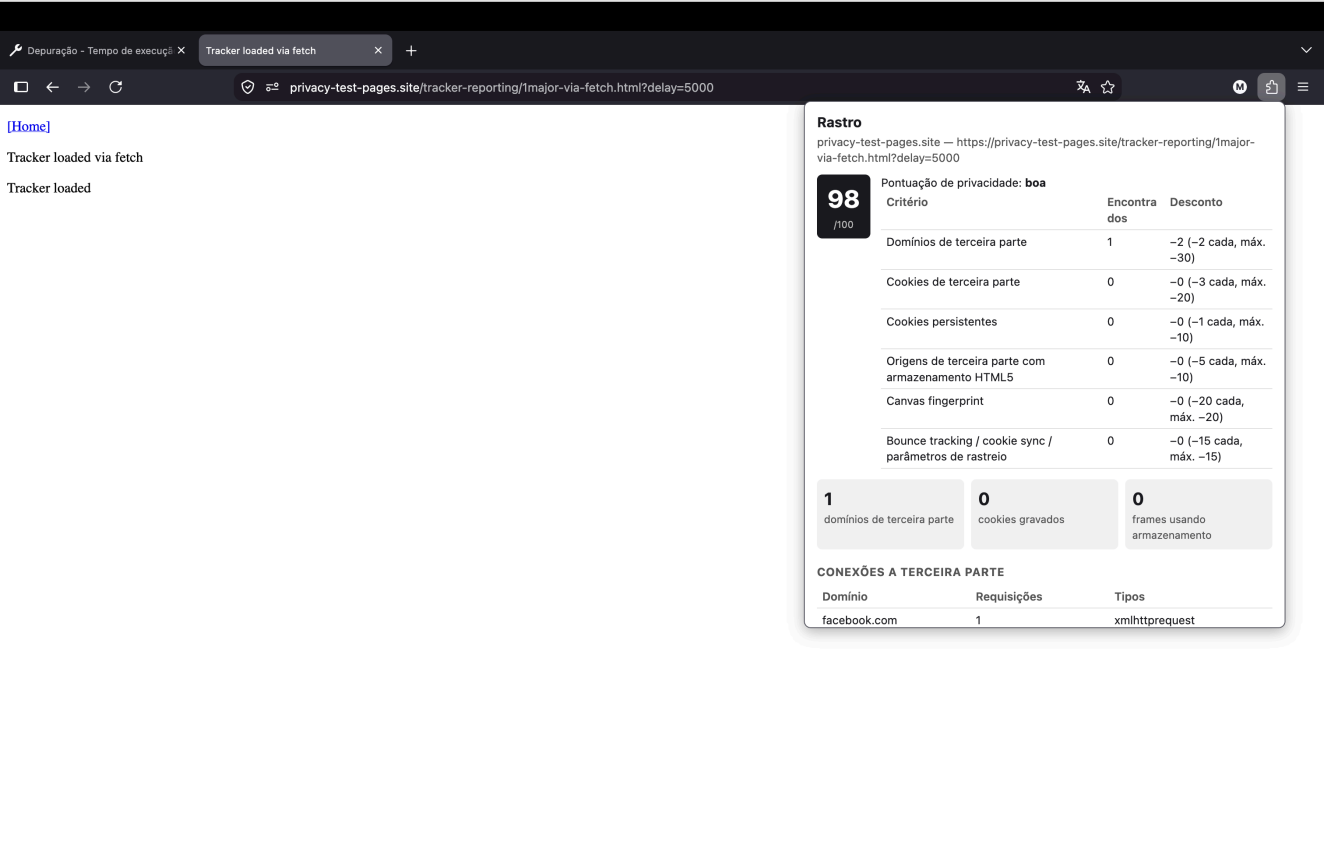


Figura 7. Tracker Reporting, via fetch com delay de 5 s

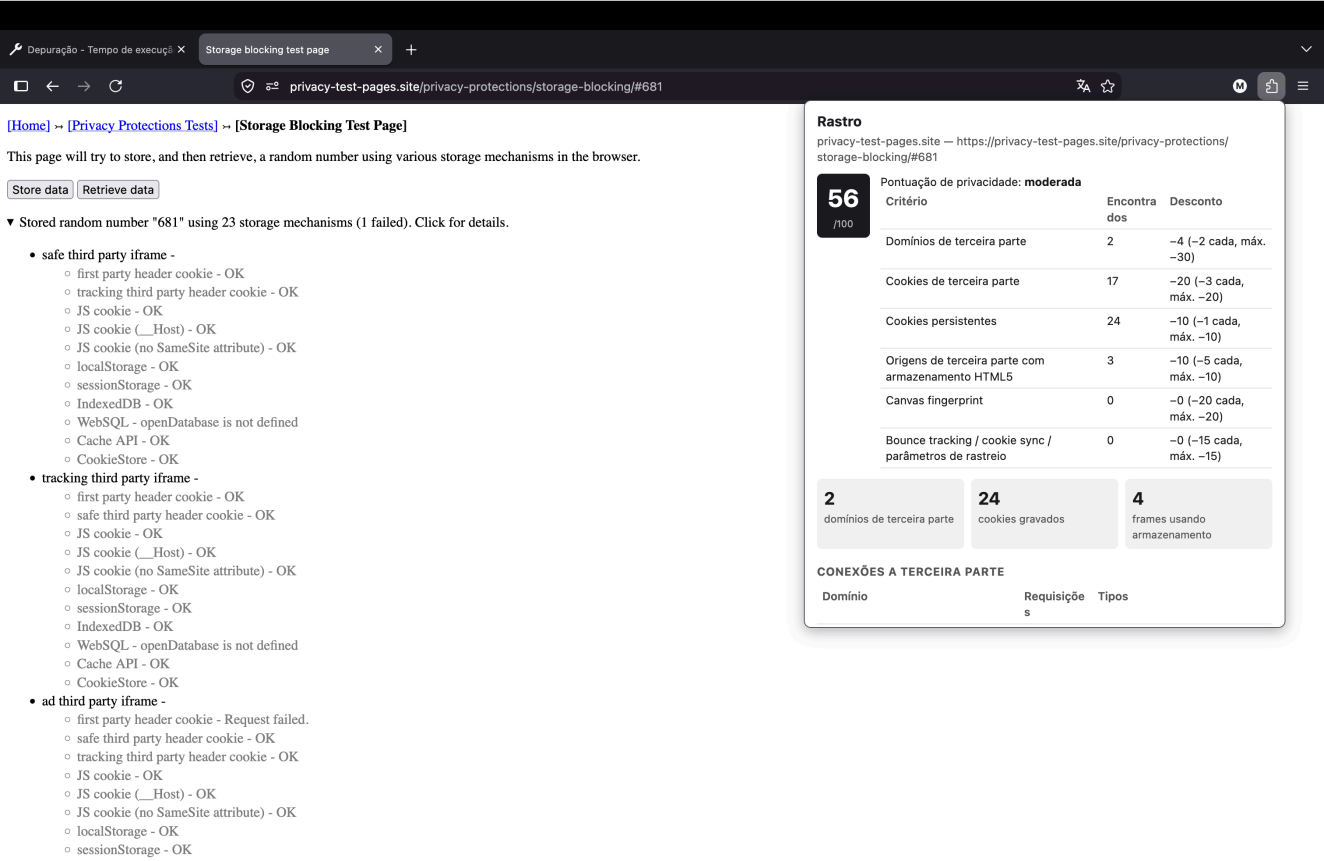


Figura 8. Storage blocking (execução 681)

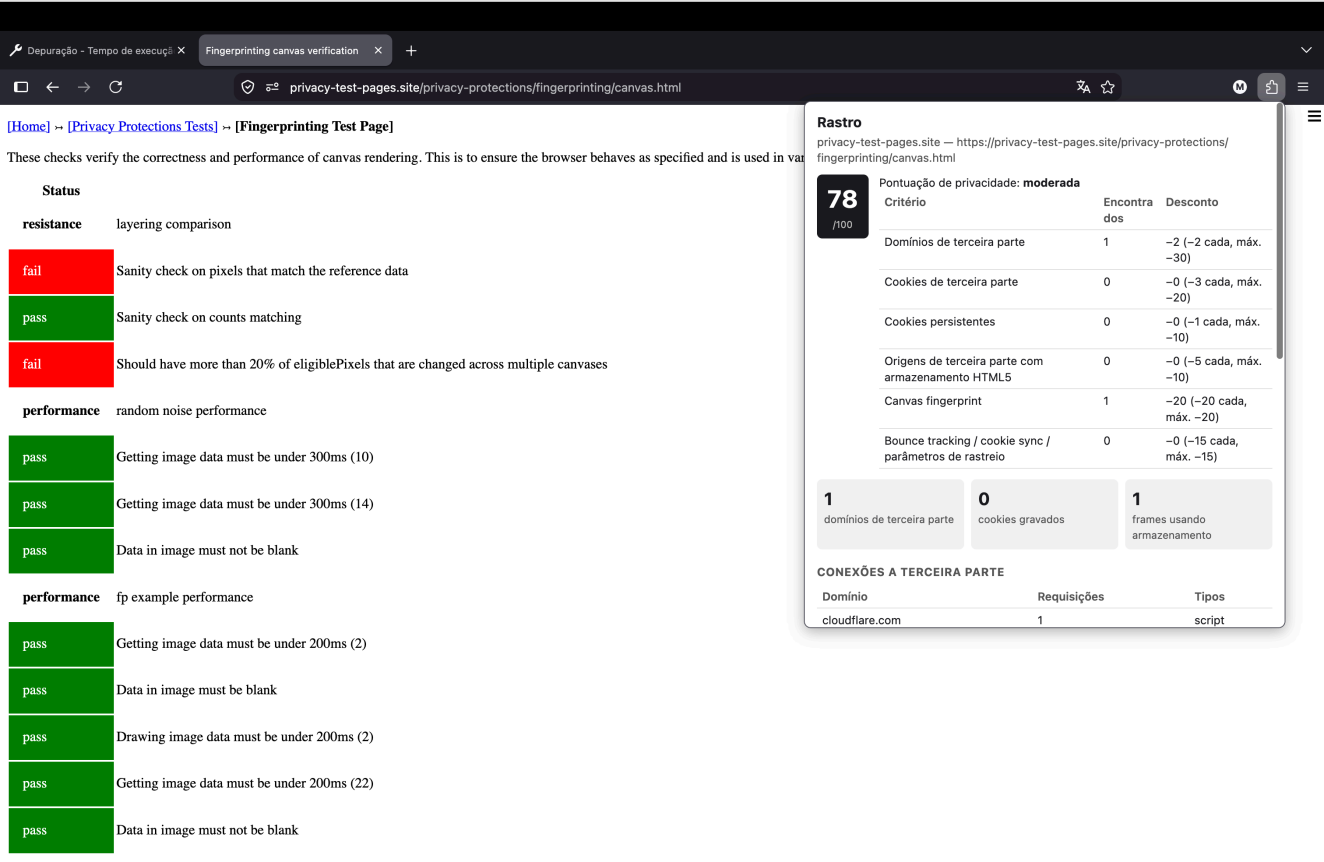


Figura 9. Fingerprinting canvas verification

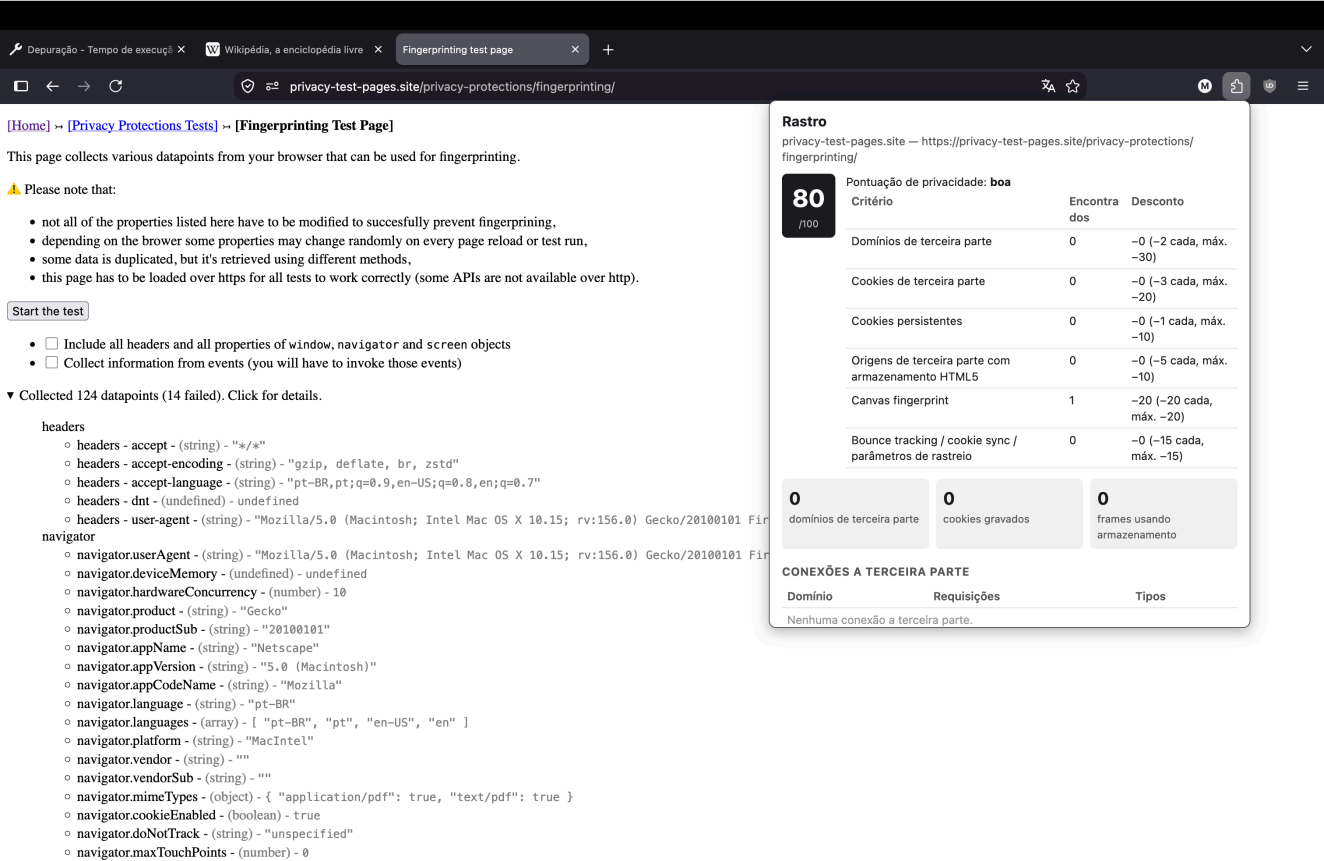


Figura 10. Fingerprinting

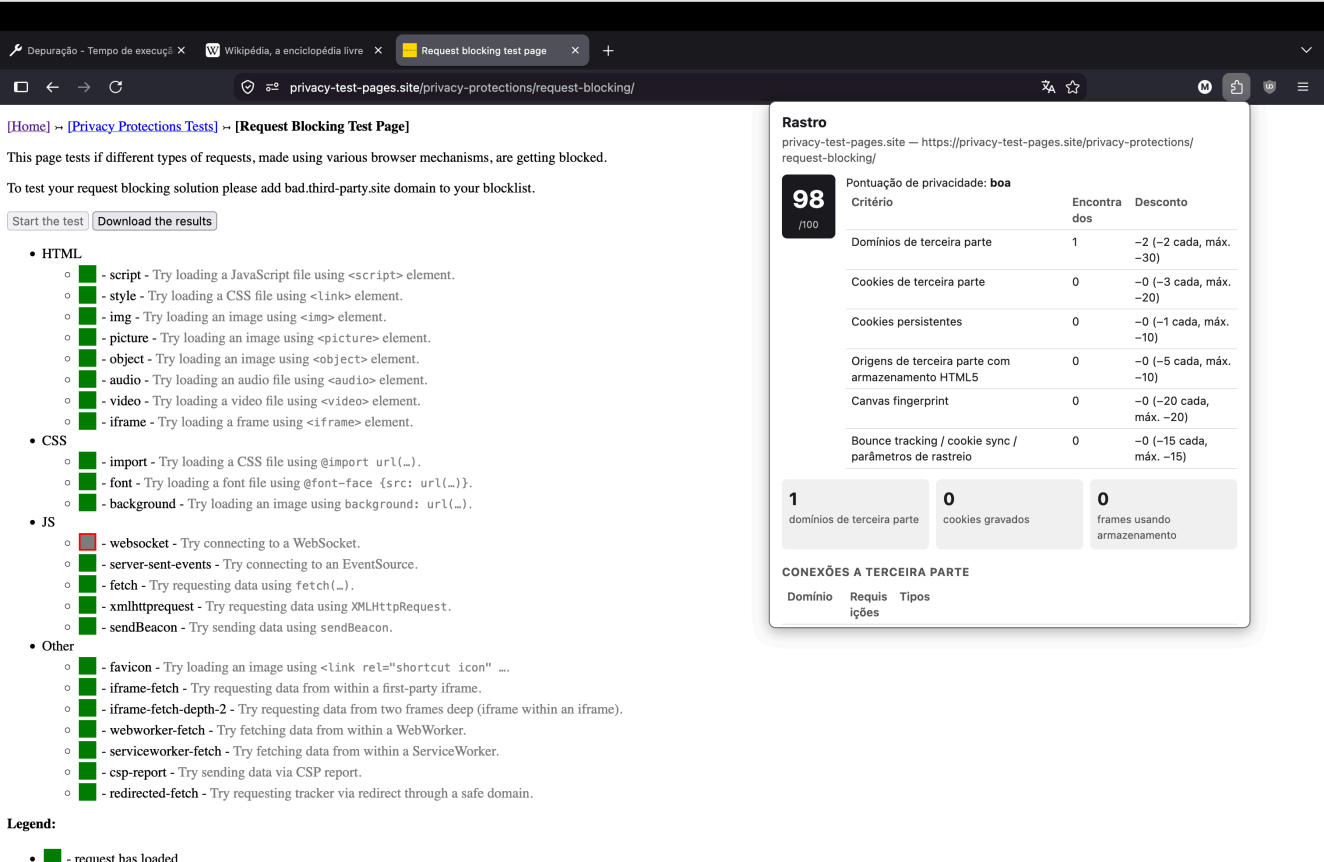


Figura 11. Tracker Blocking

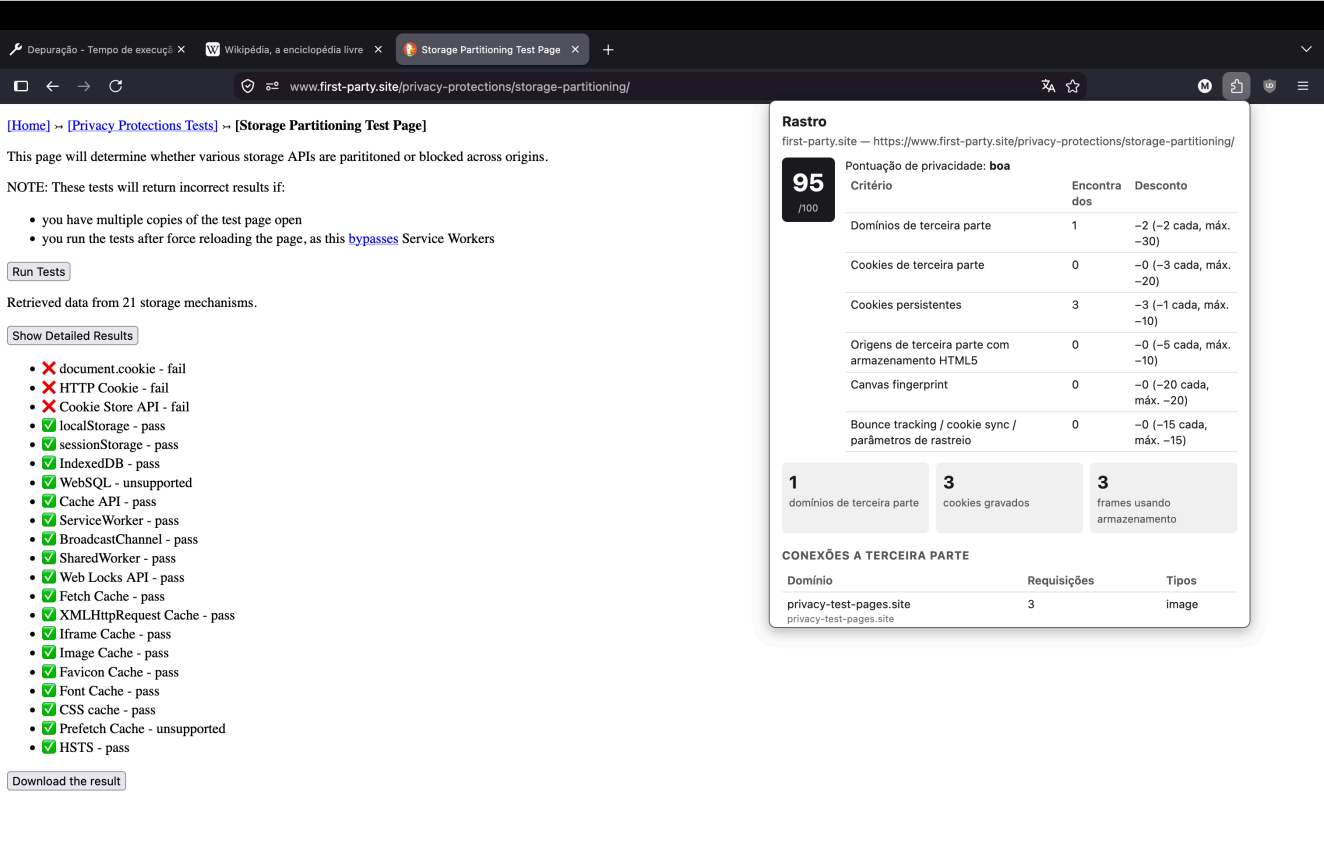


Figura 12. Storage partitioning

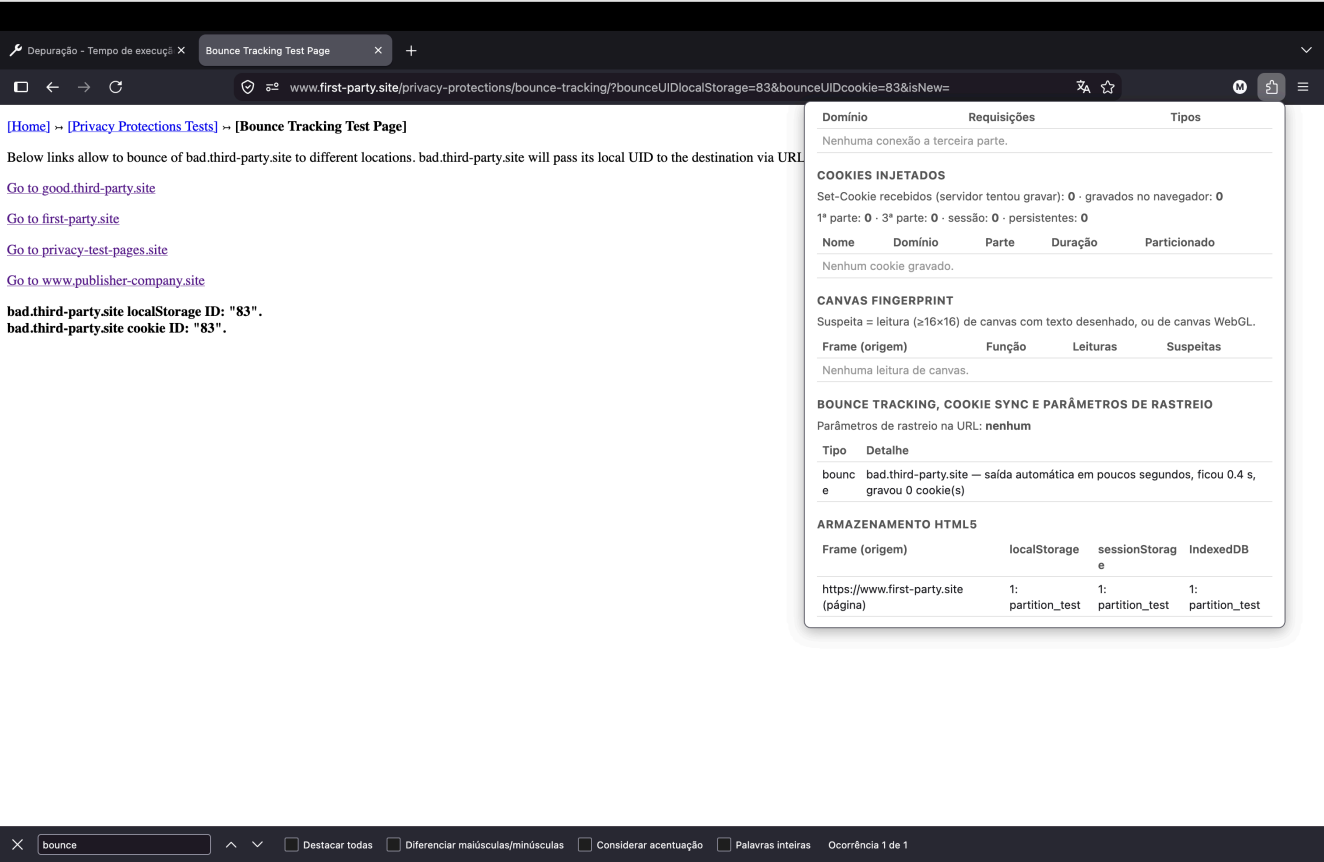


Figura 13. Bounce tracking, Go to first-party.site (ID 83 já existente no intermediário: isNew vazio, 0 cookies gravados)

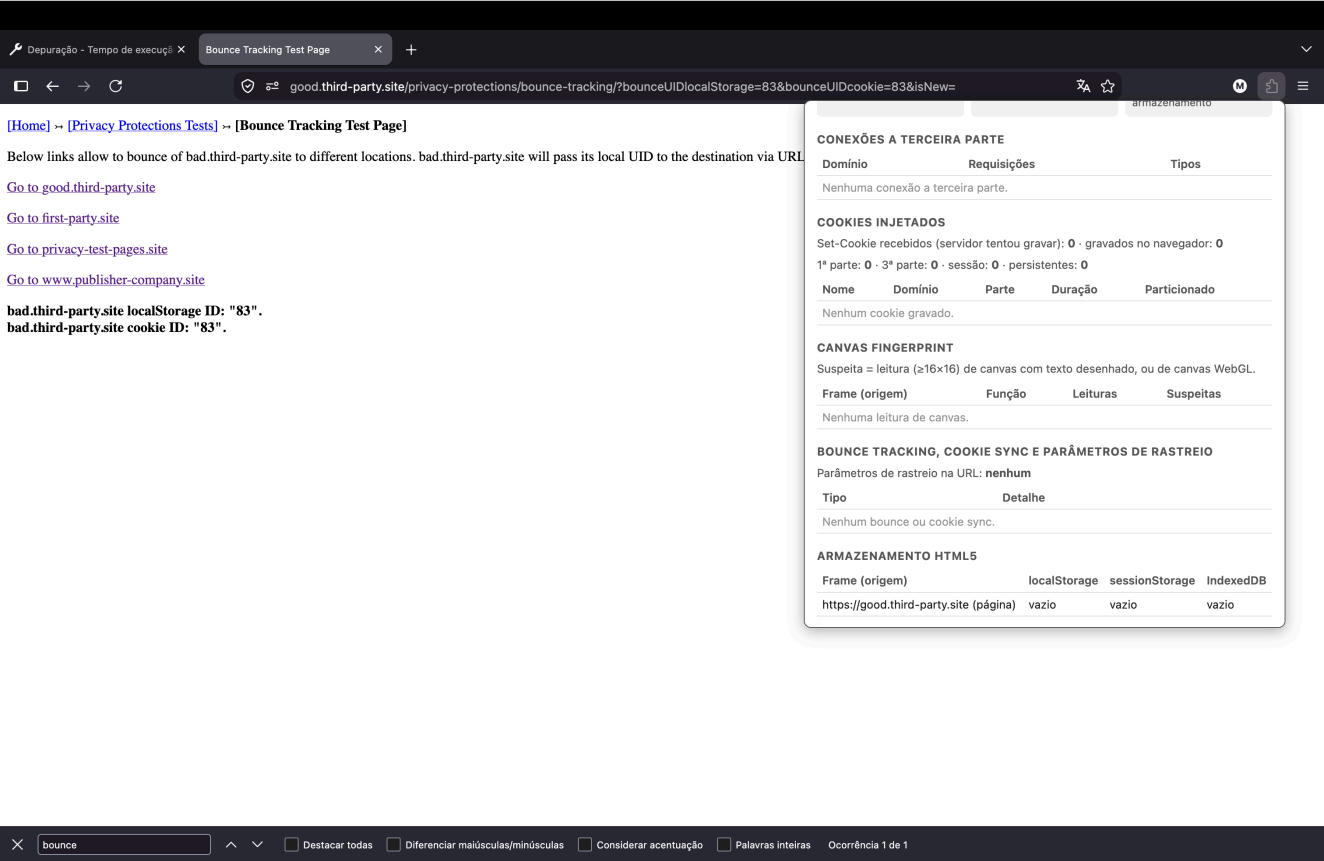


Figura 14. Bounce tracking, Go to good.third-party.site (sem bounce, mesmo eTLD+1)

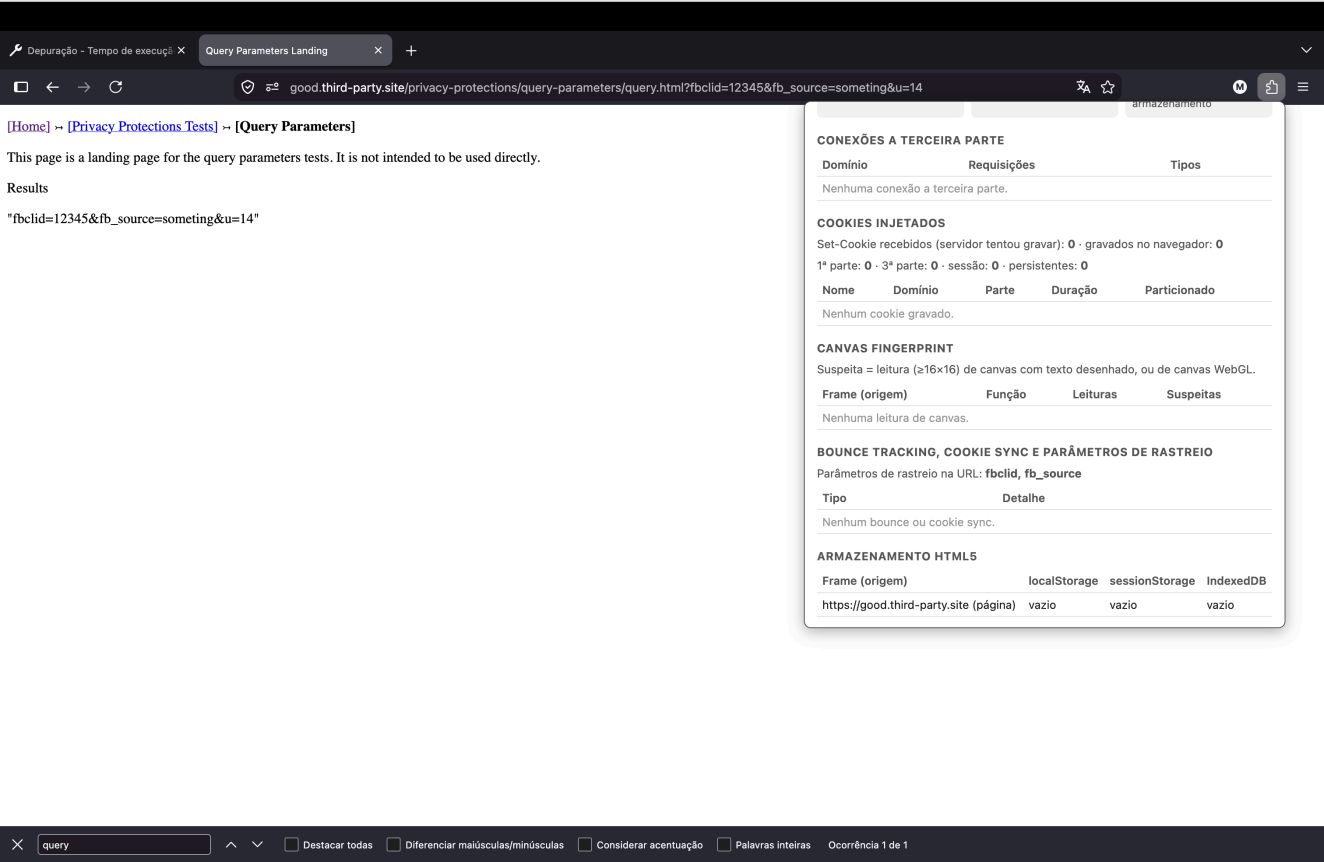


Figura 15. Query parameters, terceiro link: landing em good.third-party.site com fbclid, fb_source e u

4. Entregável 3: análise de 3 sites reais

Sites de escolha livre: `pt.wikipedia.org` e `duckduckgo.com`, esperados com pouco rastreamento, para contraste, e `www.gov.br/pt-br`, que carrega Google Tag Manager. Em cada um: dados limpos, página inicial sem login com a extensão carregada e o uBlock desligado, espera até estabilizar, prints do popup e HAR exportado da aba Rede. Depois, uBlock ligado, página recarregada e capturados o painel e o registrador dele (a lista requisição por requisição, filtrada pelas bloqueadas). Blacklight gerado em `themarkup.org/blacklight`. Nenhum aviso de cookies foi respondido: a medida é o que o site faz antes do consentimento, como faz o Blacklight. Arquivos em `evidencias/sites/<site>/`.

Blacklight e uBlock rotulam por listas de rastreadores; o plugin conta todo domínio de terceira parte, inclusive CDN. Por isso o plugin lista mais domínios, e a reconciliação diz o que cada um é.

4.1 pt.wikipedia.org

Prints deste site: figuras 16, 17, 18, 19; painel do uBlock no apêndice, figura 35.

Fonte	O que encontrou
Plugin	Nota 68. 1 domínio de terceira parte, <code>wikimedia.org</code> (<code>intake-analytics</code> , <code>thumb</code> , <code>meta</code> , <code>auth</code> , <code>upload</code> ; 12 requisições). 26 <code>Set-Cookie</code> recebidos, 12 gravados: 1 de primeira parte, 11 de terceira; 2 de sessão, 10 persistentes (<code>WMF-Uniq</code> 364 dias, <code>WMF-Last-Access</code> 32 dias, <code>NetworkProbeLimit</code> 0 dias, <code>GeoIP</code> sessão), particionados. Sem storage de terceiros, canvas, bounce ou sync.
Blacklight	0 ad trackers, 4 third-party cookies, nada nas demais categorias.
uBlock Origin	1 bloqueio: <code>POST intake-analytics.wikimedia.org/v1/events?hasty=true</code> (beacon), regra <code> intake-analytics.wikimedia.org^</code> (figura 18).
HAR	38 requisições: 22 <code>pt.wikipedia.org</code> , 13 <code>*.wikimedia.org</code> , 3 <code>data:</code> . 31 <code>Set-Cookie</code> : os 26 de <code>*.wikimedia.org</code> coincidem com o popup; os 5 de primeira parte vêm de uma resposta de <code>load.php</code> e só 1 aparece gravado. A primeira requisição já enviava esses 5 cookies (a limpeza não foi feita nesta visita) e 4 voltaram com o mesmo valor: causa provável é a limitação do <code>cookies.onChanged</code> da seção 6. Não afeta a nota, que só desconta terceira parte.

Reconciliação:

Item	Plugin	Blacklight	uBlock	Explicação técnica
Cookies de terceira parte	11	4	—	O plugin conta cada par nome e host; agrupando por nome, o HAR tem exatamente 4 cookies de <code>*.wikimedia.org</code> (<code>GeoIP</code> , <code>NetworkProbeLimit</code> , <code>WMF-Last-Access</code> , <code>WMF-Uniq</code>), os mesmos 4 do Blacklight. São da própria Wikimedia, mas <code>wikimedia.org</code> e <code>wikipedia.org</code> são eTLD+1 diferentes.
<code>wikimedia.org</code> como terceiro	1 (-2)	0 ad trackers	1 bloqueio	O plugin conta sem rotular; o Blacklight só conta domínios da lista de anúncios dele; o uBlock bloqueou só a telemetria (<code>POST intake-analytics.../events</code> , 4 vezes no HAR sem uBlock) e deixou passar imagens e scripts do mesmo domínio. Concordam no fato, divergem no rótulo.
<code>NetworkProbeLimit</code> "persistente (0 dias)"	3 persistentes	—	—	Chega com <code>Max-Age=3600</code> . O plugin trata qualquer cookie com expiração como persistente; certo, mas infla o critério 3 em 3 pontos (seção 6).
Canvas, storage de terceiros, bounce, sync	0	não encontrado	—	Concordam; o HAR não tem domínio de anúncio nem redirecionamento entre sites.

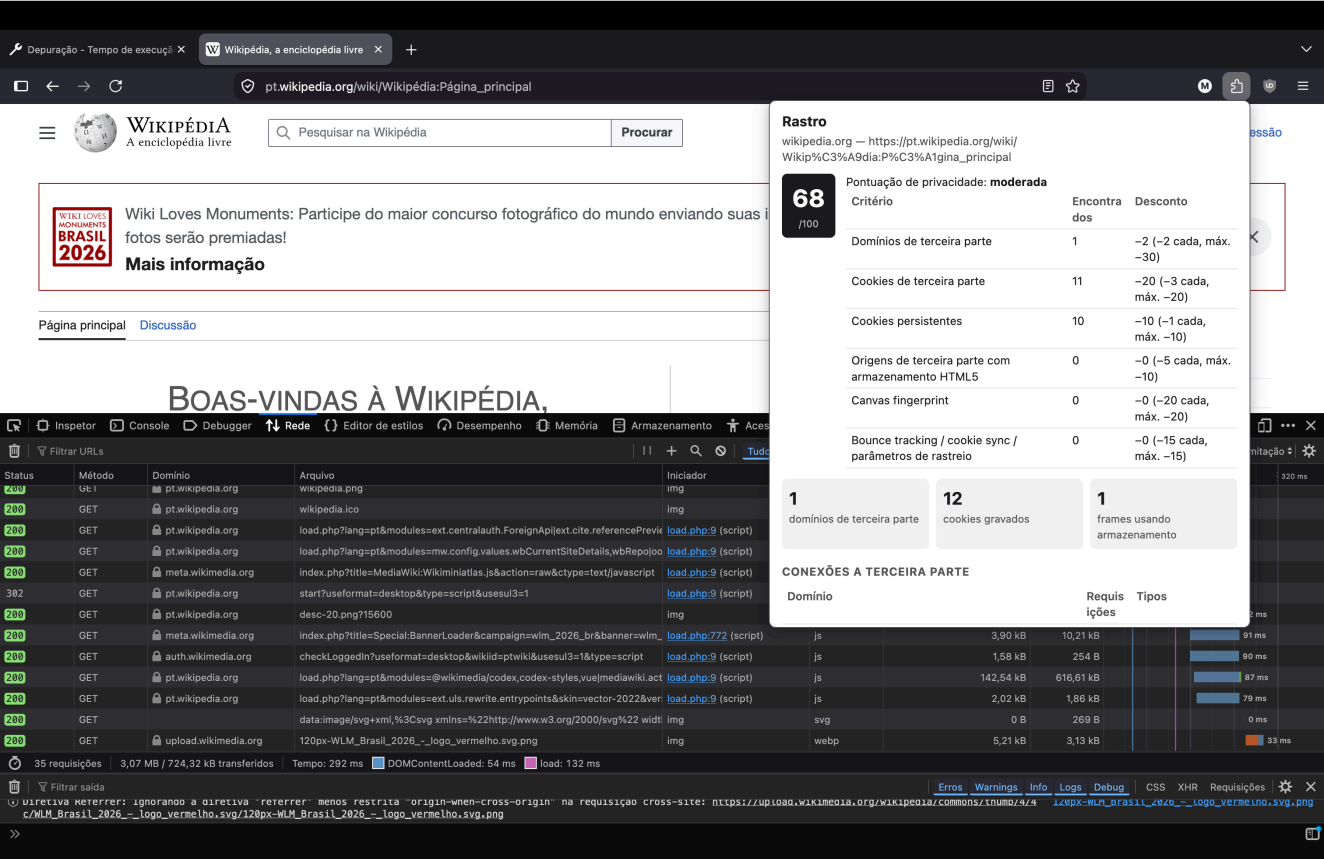


Figura 16. Wikipédia, popup do plugin com a nota e os critérios

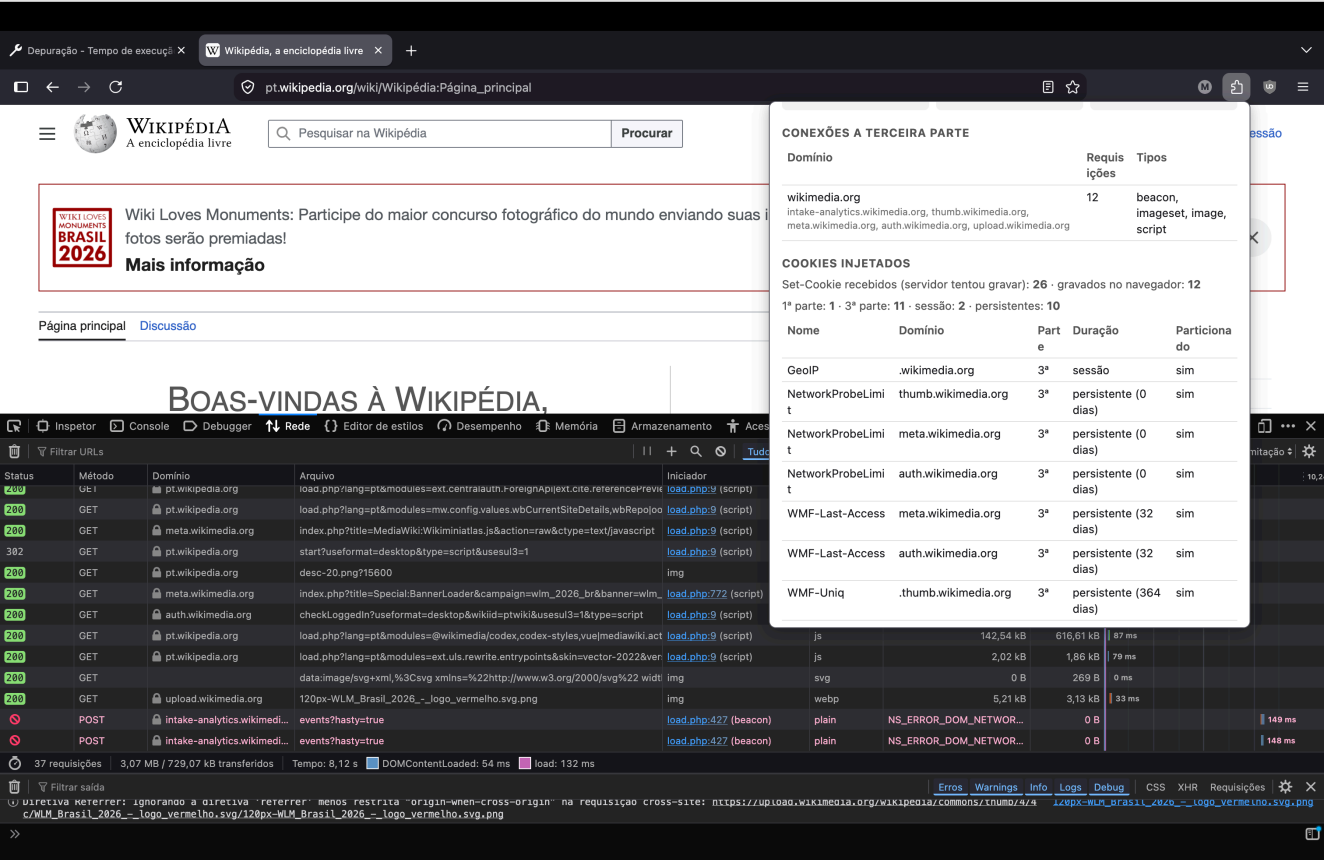


Figura 17. Wikipédia, terceiros e cookies injetados. Os dois POST a intake-analytics com NS_ERROR_DOM_NETWORK na aba Rede são falhas do beacon, não bloqueio: no HAR as quatro requisições a esse host respondem 202.

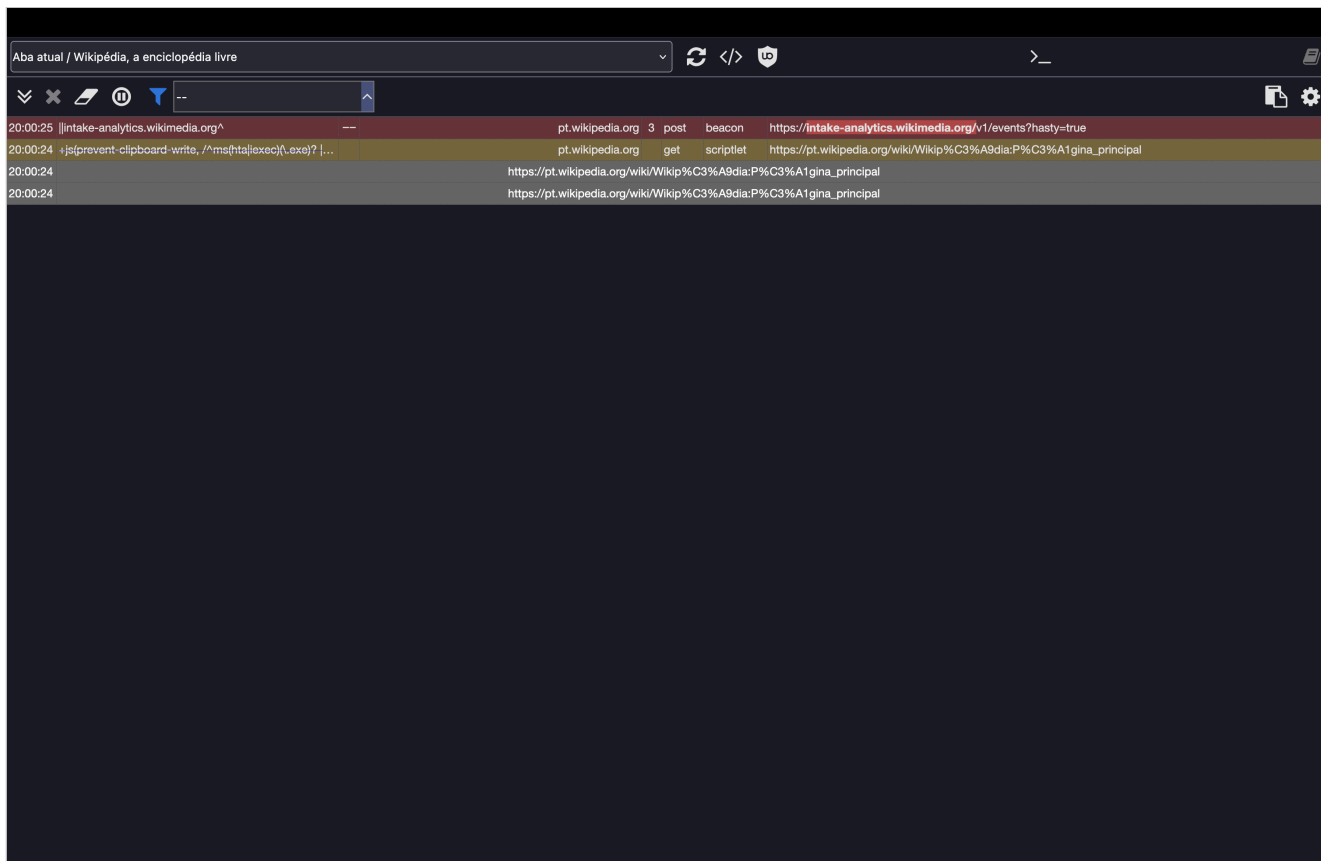


Figura 18. Wikipédia, registrador do uBlock filtrado pelas requisições bloqueadas

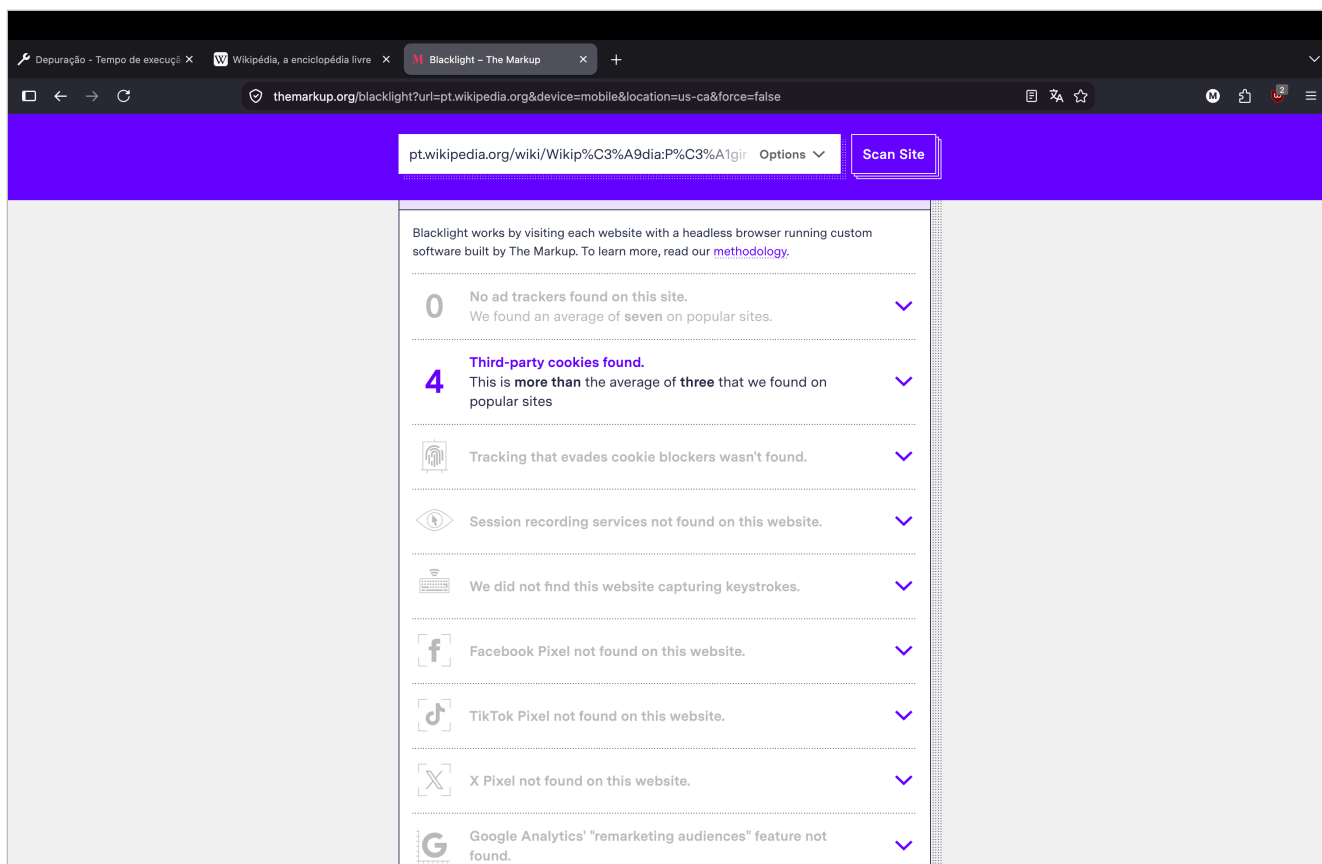


Figura 19. Wikipédia, Blacklight

4.2 www.gov.br/pt-br

Prints deste site: figuras 20, 21, 22, 23, 24, 25; painel do uBlock no apêndice, figura 36.

A nota caiu de 80 para 55 durante o carregamento, porque Tag Manager, Analytics e mPulse dispararam depois do `load`. Prints e HAR são do estado estabilizado.

Fonte	O que encontrou
Plugin	Nota 55. 11 domínios de terceira parte: <code>ebc.com.br</code> 12 requisições (iframe da Agência Gov), <code>cloudflare.com</code> 11, <code>sistema.gov.br</code> 10, <code>go-mpulse.net</code> 4, <code>vlibras.gov.br</code> 3, <code>jsdelivr.net</code> 3, <code>googletagmanager.com</code> 2, <code>google.com</code> 2, <code>browser-update.org</code> 1, <code>doubleclick.net</code> 1, <code>google.com.br</code> 1. 89 Set-Cookie recebidos, 4 gravados: 2 de primeira parte e sessão (TSceab889027, Encrypted-Local-Storage-Key), 2 de terceira parte, persistentes por 400 dias e particionados (<code>_ga</code> , <code>_ga_X0DQ0CT40G</code> em <code>.ebc.com.br</code>). Sem storage de terceiros nem canvases. Cookie sync (-15): <code>cid=72351855...</code> enviado a <code>google.com</code> , <code>doubleclick.net</code> e <code>google.com.br</code> (figura 23).
Blacklight	1 ad tracker, "a script belonging to the company Alphabet, Inc." (figura 25); 0 third-party cookies; "Google Analytics remarketing audiences" não encontrado; nada nas demais categorias. Visita com <code>device=mobile</code> , <code>location=us-ca</code> .
uBlock Origin	5 bloqueios, 9 de 12 domínios conectados. Registrador (figura 24): <code>s.go-mpulse.net/boomerang/...</code> 2 vezes (<code> go-mpulse.net^</code>), <code>www.googletagmanager.com/gtag/js?id=G-X0DQ0CT40G</code> 2 vezes (<code> googletagmanager.com^</code> , com substituição por um script neutro via <code>redirect-rule</code>) e <code>browser-update.org/update.min.js</code> (<code> browser-update.org^\$3p</code>). Os quatro primeiros pedidos pelo iframe <code>agenciagov.ebc.com.br</code> .
HAR	140 requisições. Rastreamento: <code>gtag/js?id=G-X0DQ0CT40G</code> (2), <code>analytics.google.com/g/collect</code> (2), <code>stats.g.doubleclick.net/g/collect?...</code> <code>cid=1372646340.1790629402</code> , <code>www.google.com.br/ads/ga-audiences?...</code> <code>cid=1372646340.1790629402</code> , <code>s.go-mpulse.net/boomerang</code> (2), <code>c.go-mpulse.net/api/config.json?...d=agenciagov.ebc.com.br</code> (4), <code>browser-update.org/update.min.js</code> . Os 89 Set-Cookie são o TSceab889027 com valor novo em cada resposta. Não há Set-Cookie para <code>_ga</code> . Popup e HAR diferem pouco nas contagens (12 e 10 para <code>ebc.com.br</code> ; 138 e 140 requisições) por serem contadores diferentes; o conjunto dos 11 domínios é o mesmo.

Reconciliação:

Item	Plugin	Blacklight	uBlock	Explicação técnica
Domínios de terceira parte	11	1 ad tracker	12 conectados, 5 bloqueados	Três critérios. O plugin conta eTLD+1 distintos, o que inclui CDNs, o iframe da EBC e até <code>sistema.gov.br</code> e <code>vlibras.gov.br</code> , porque <code>gov.br</code> está na Public Suffix List. O uBlock conta hostnames e bloqueou mPulse, GTM e browser-update; Analytics, DoubleClick e <code>ga-audiences</code> não aparecem no registrador porque o <code>gtag.js</code> , que os dispara, é bloqueado antes. O Blacklight rotula um script da Alphabet; no HAR o único script da Alphabet é o <code>gtag.js</code> .
<code>_ga</code> , <code>_ga_X0DQ0CT40G</code>	2 cookies de terceira parte, 400 dias	0 third-party cookies	—	Sem Set-Cookie no HAR: são gravados por <code>gtag.js</code> via <code>document.cookie</code> dentro do iframe <code>agenciagov.ebc.com.br</code> . Para o iframe são de primeira parte; para a aba são de terceira, e o Firefox os particiona. O plugin classifica em relação à aba. Hipótese para o 0 do Blacklight: a visita mobile não carrega o iframe, e sem ele o cookie não é criado.
Cookie sync (critério 6)	detectado (-15)	—	—	Análise do HAR: <code>cid=1372646340.1790629402</code> , o identificador do cookie <code>_ga</code> (formato <code>GA1.1.<cid></code>), vai para <code>stats.g.doubleclick.net</code> e <code>google.com.br/ads/ga-audiences</code> . O popup detecta o mesmo (figura 23, com outro <code>cid</code> por ser visita nova). O Blacklight não tem essa categoria. Ressalva: o popup lista também <code>tid</code> , <code>gtm</code> , <code>gcd</code> e <code>tag_exp</code> , que são configuração do GA (seção 6).
GA remarketing (<code>ga-audiences</code>)	contado em <code>google.com.br</code>	não encontrado	não ocorre, <code>gtag.js</code> bloqueado antes	O HAR tem GET <code>www.google.com.br/ads/ga-audiences</code> com 200, o tipo de requisição que o Blacklight chama de remarketing. Mesma hipótese do <code>_ga</code> . O plugin só conta o domínio.
<code>go-mpulse.net</code> (mPulse)	4 (-2)	—	bloqueado	Monitoramento de desempenho do iframe da EBC (<code>d=agenciagov.ebc.com.br</code> na URL). Está nas listas do uBlock; não é anúncio, por isso o Blacklight ignora.
Canvas	0	não encontrado	—	Concordam.

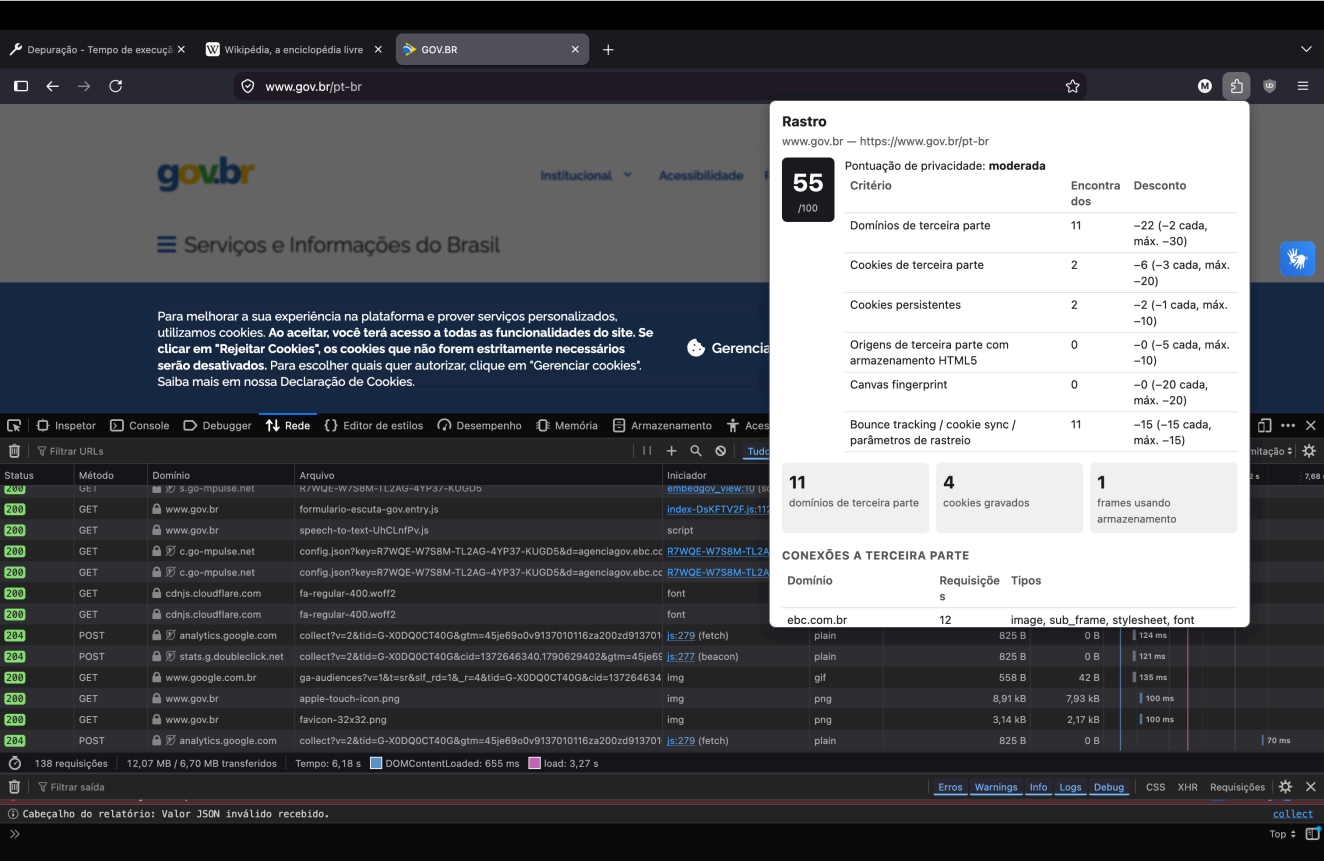


Figura 20. gov.br, popup do plugin com a nota e os critérios

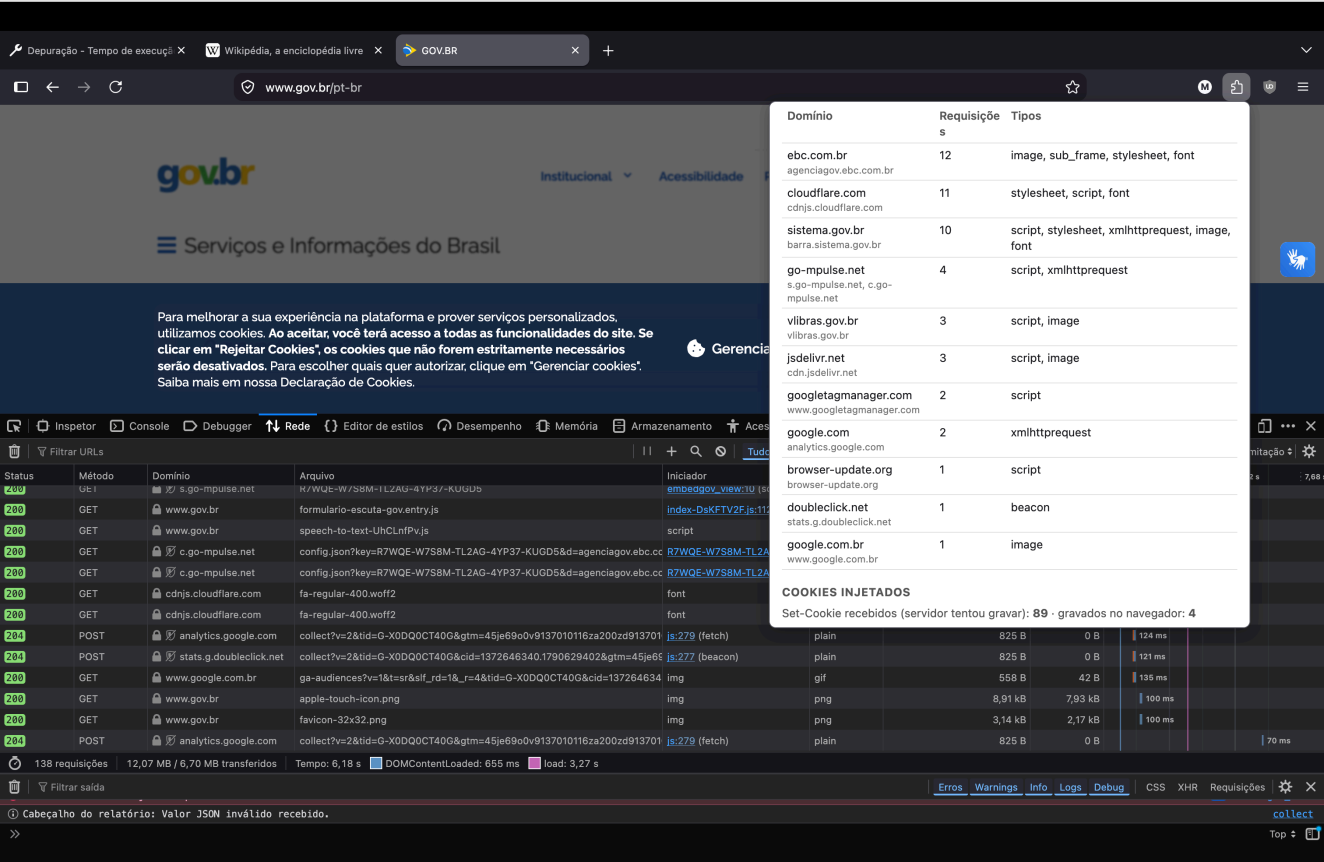


Figura 21. gov.br, os 11 domínios de terceira parte

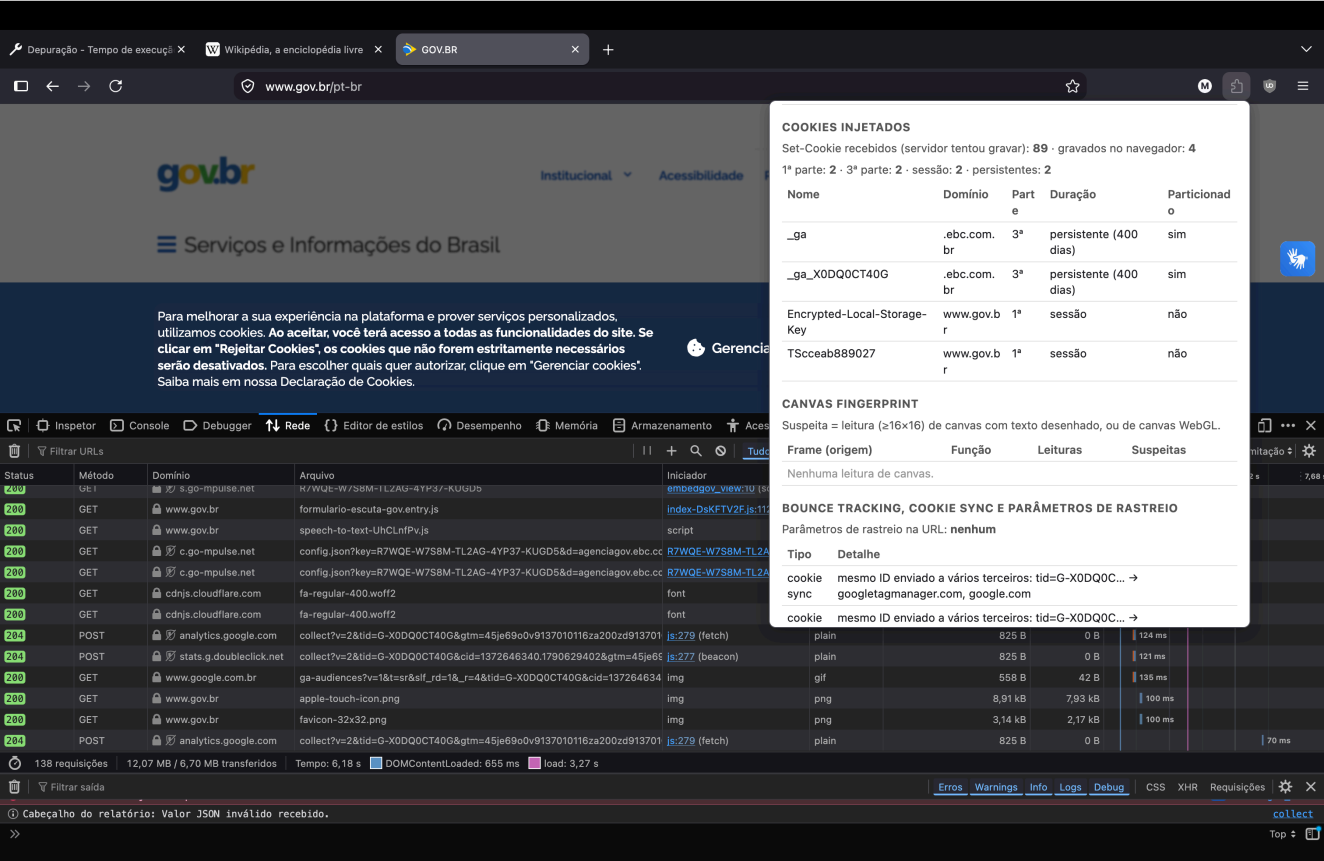


Figura 22. gov.br, cookies, canvas e cookie sync

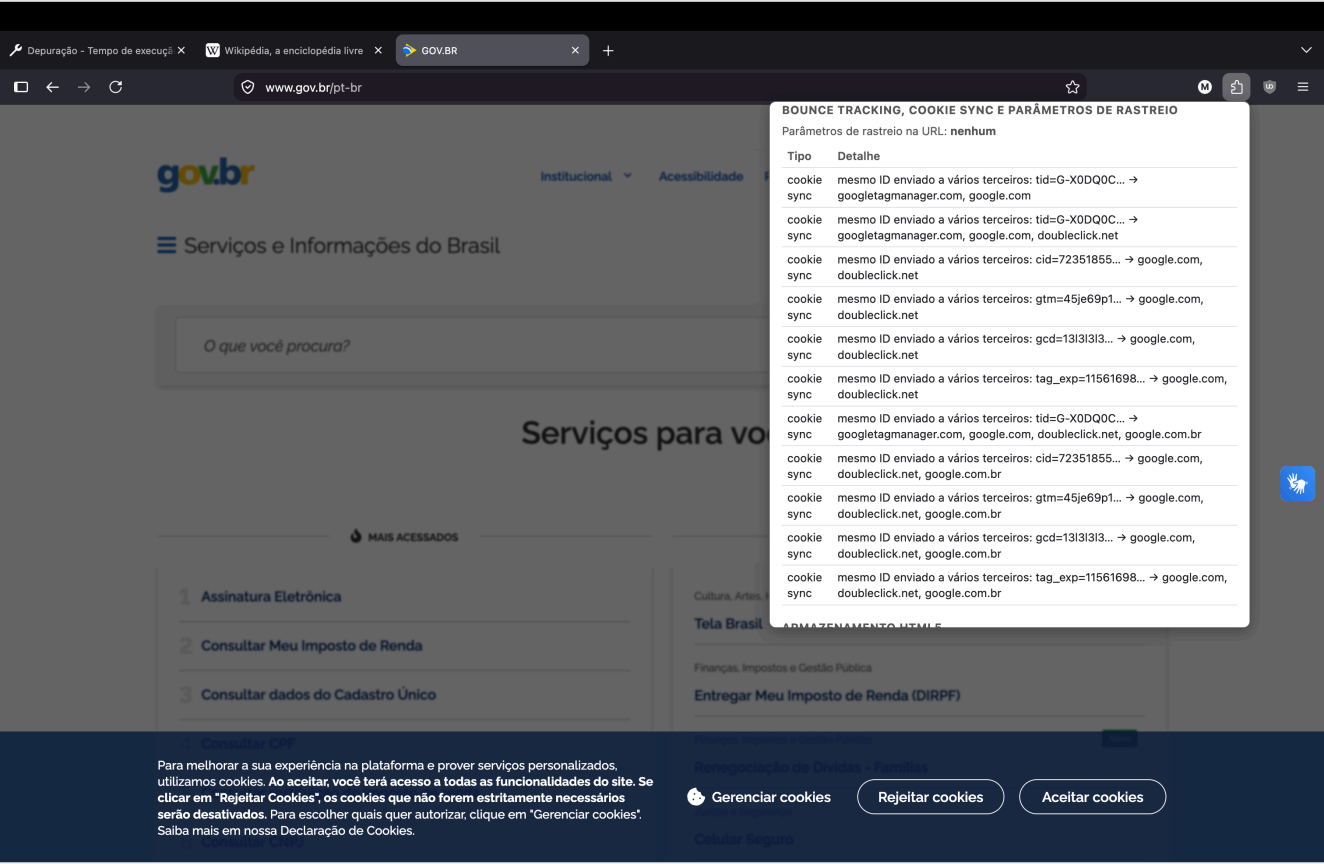


Figura 23. gov.br, seção de cookie sync completa (visita nova, com dados do site limpos)

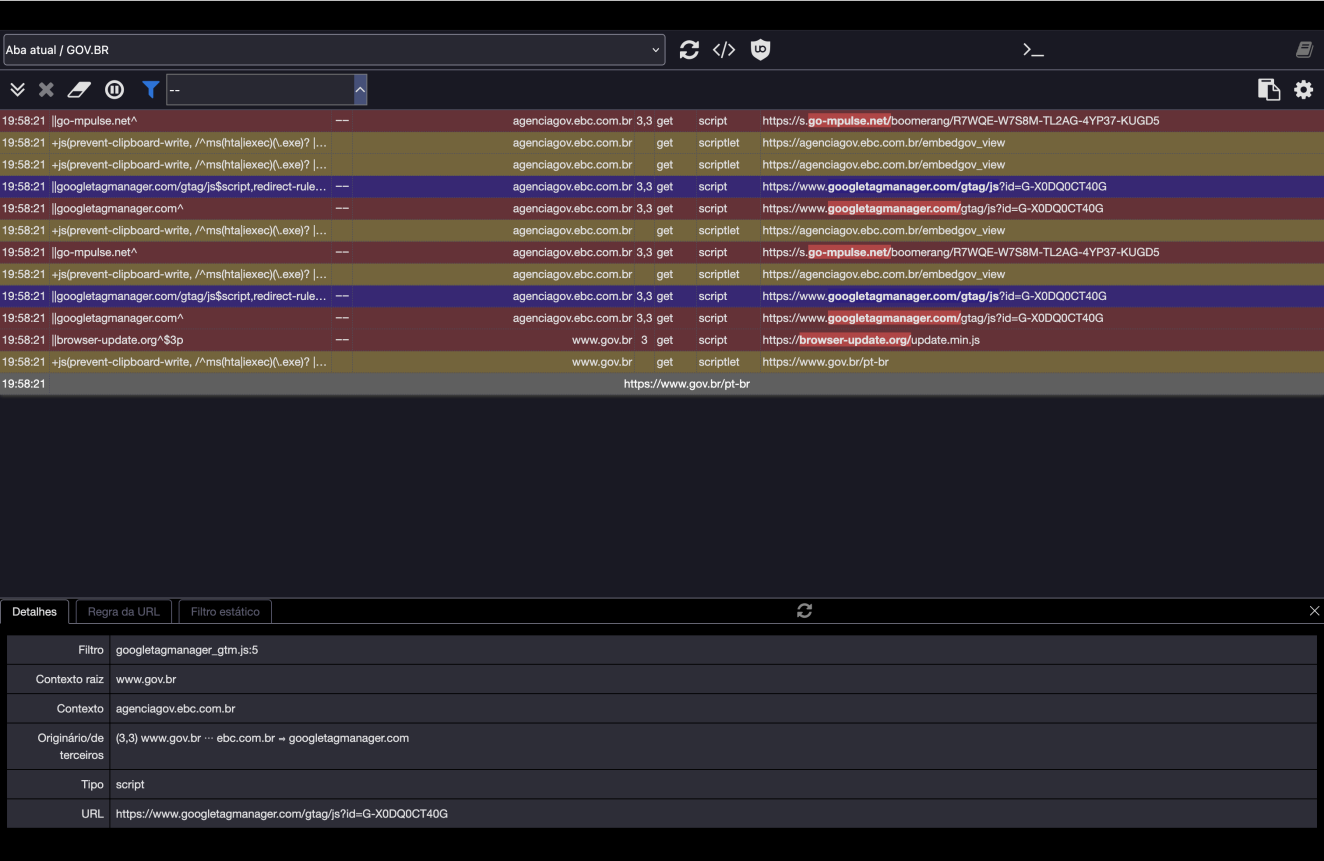


Figura 24. gov.br, registrador do uBlock filtrado pelas requisições bloqueadas

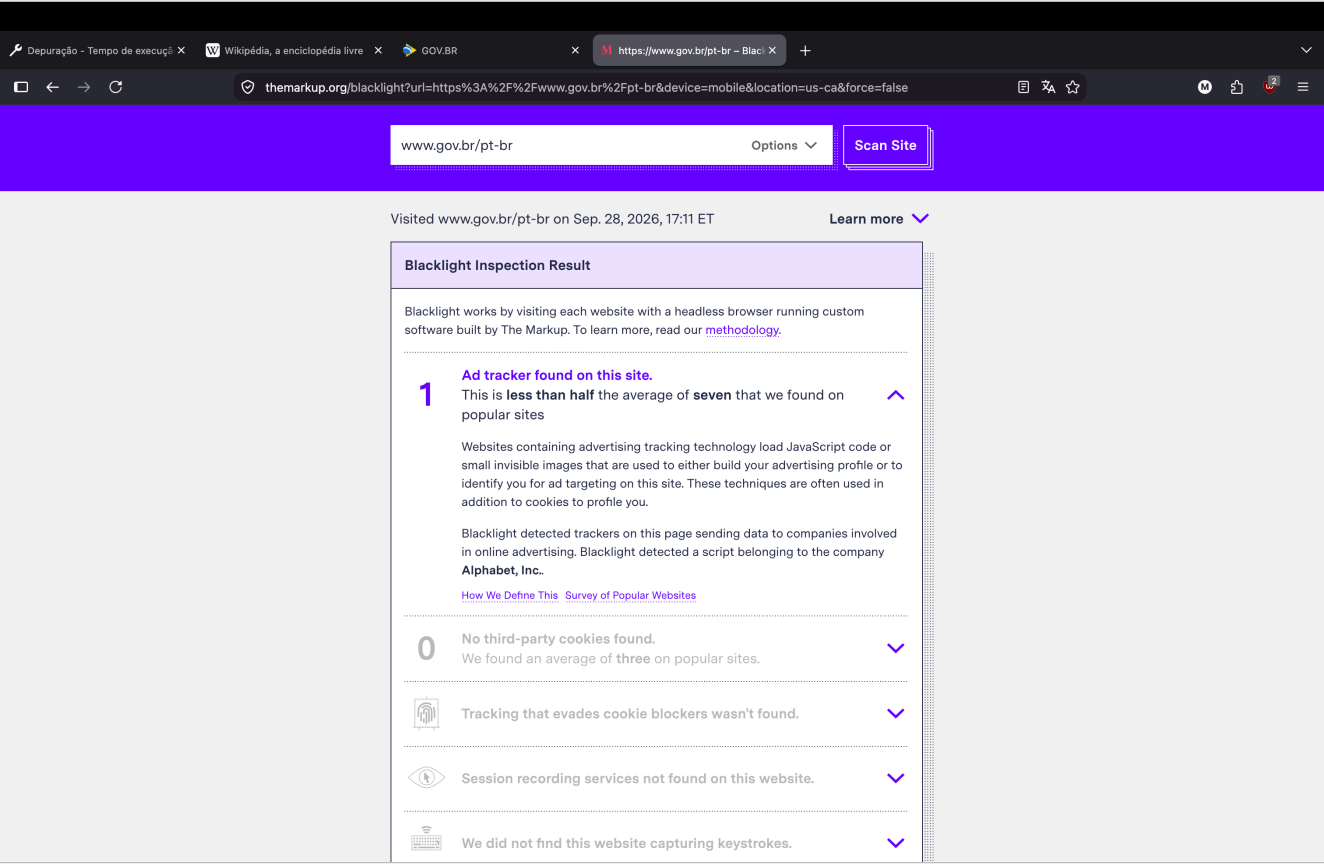


Figura 25. gov.br, Blacklight com a linha do ad tracker expandida (script da Alphabet, Inc.)

4.3 duckduckgo.com

Prints deste site: figuras 26, 27, 28, 29; painel do uBlock no apêndice, figura 37.

Fonte	O que encontrou
-------	-----------------

Plugin	Nota 100. Nenhum terceiro, nenhum <code>Set-Cookie</code> , nenhum cookie, storage do próprio site vazio, nenhum canvas, bounce, sync ou parâmetro de rastreo.
Blacklight	0 em todas as categorias.
uBlock Origin	8 bloqueios no carregamento. Registrador (figura 28, que acumula dois carregamentos): todos <code>POST improving.duckduckgo.com/t/...</code> (beacon), regra <code> duckduckgo.com/t/</code> , primeira parte.
HAR	73 requisições: 63 <code>duckduckgo.com</code> , 10 <code>improving.duckduckgo.com (/t/page_home_impression, /t/static_webvitals, /t/static_fcp etc.)</code> . Nenhum <code>Set-Cookie</code> , nenhum cookie enviado, nenhum host fora de <code>duckduckgo.com</code> .

Reconciliação:

Item	Plugin	Blacklight	uBlock	Explicação técnica
<code>improving.duckduckgo.com</code> (telemetria)	não contado, primeira parte	não contado	8 bloqueios	Única divergência. São métricas de uso, sem cookie, para o mesmo eTLD+1. Telemetria de primeira parte sem identificador não pontua no plugin nem no Blacklight; o uBlock bloqueia pelo caminho <code>/t/</code> . É o limite da abordagem por terceira parte: não pega coleta do próprio site.
Demais critérios	0	não encontrado	—	Concordam. Site de contraste: a metodologia dá 100 a quem não usa terceiros nem cookies.

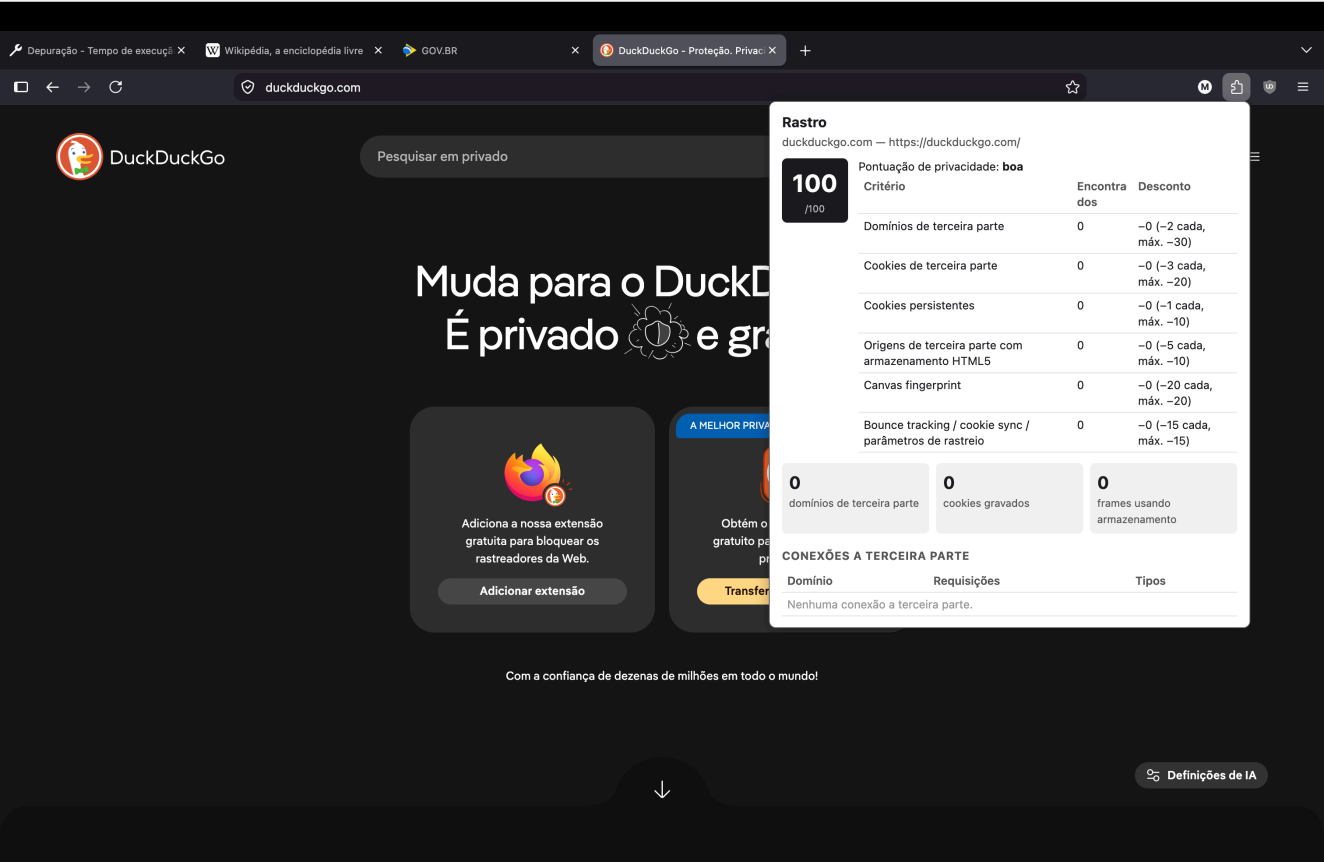


Figura 26. DuckDuckGo, popup do plugin com nota 100

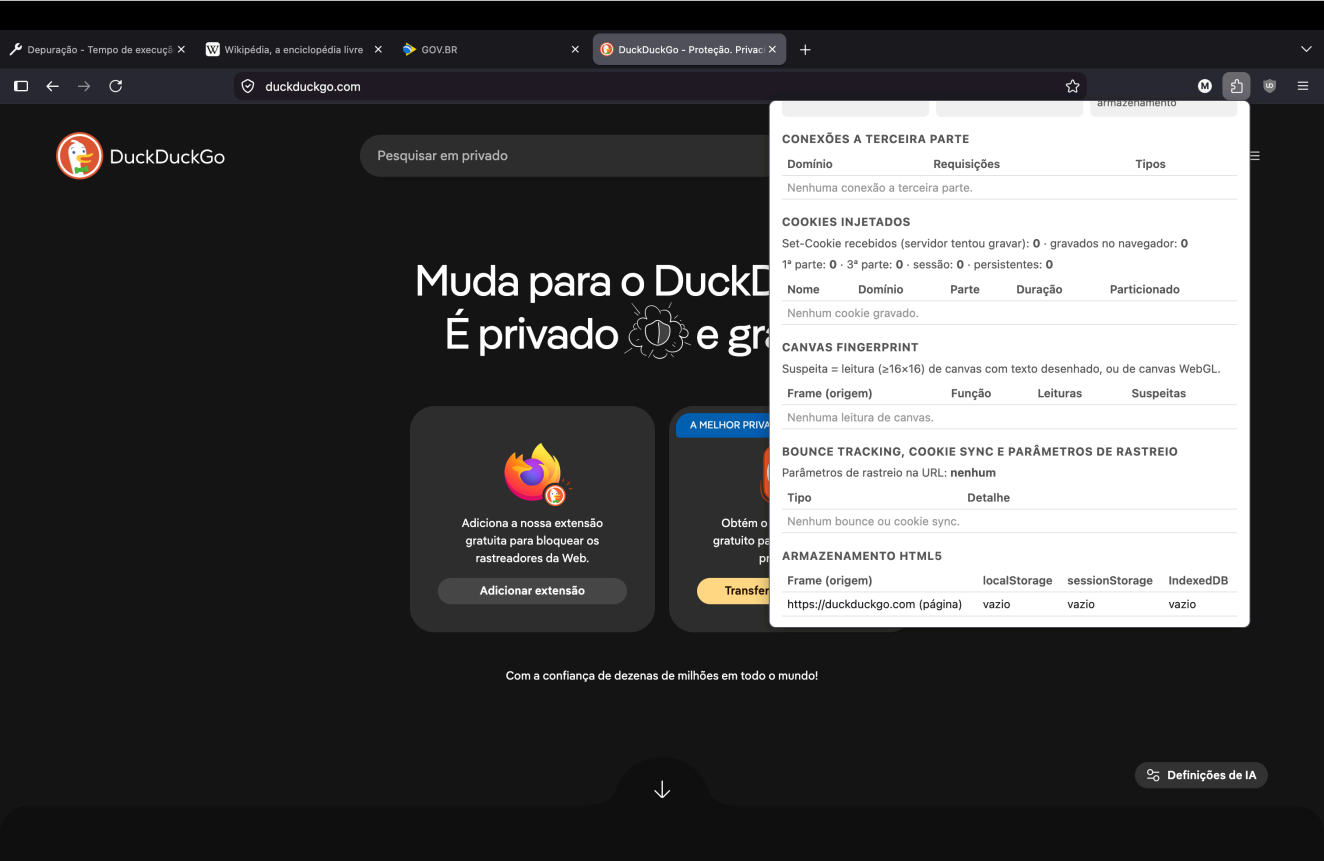


Figura 27. DuckDuckGo, cookies, canvas, bounce e armazenamento vazios

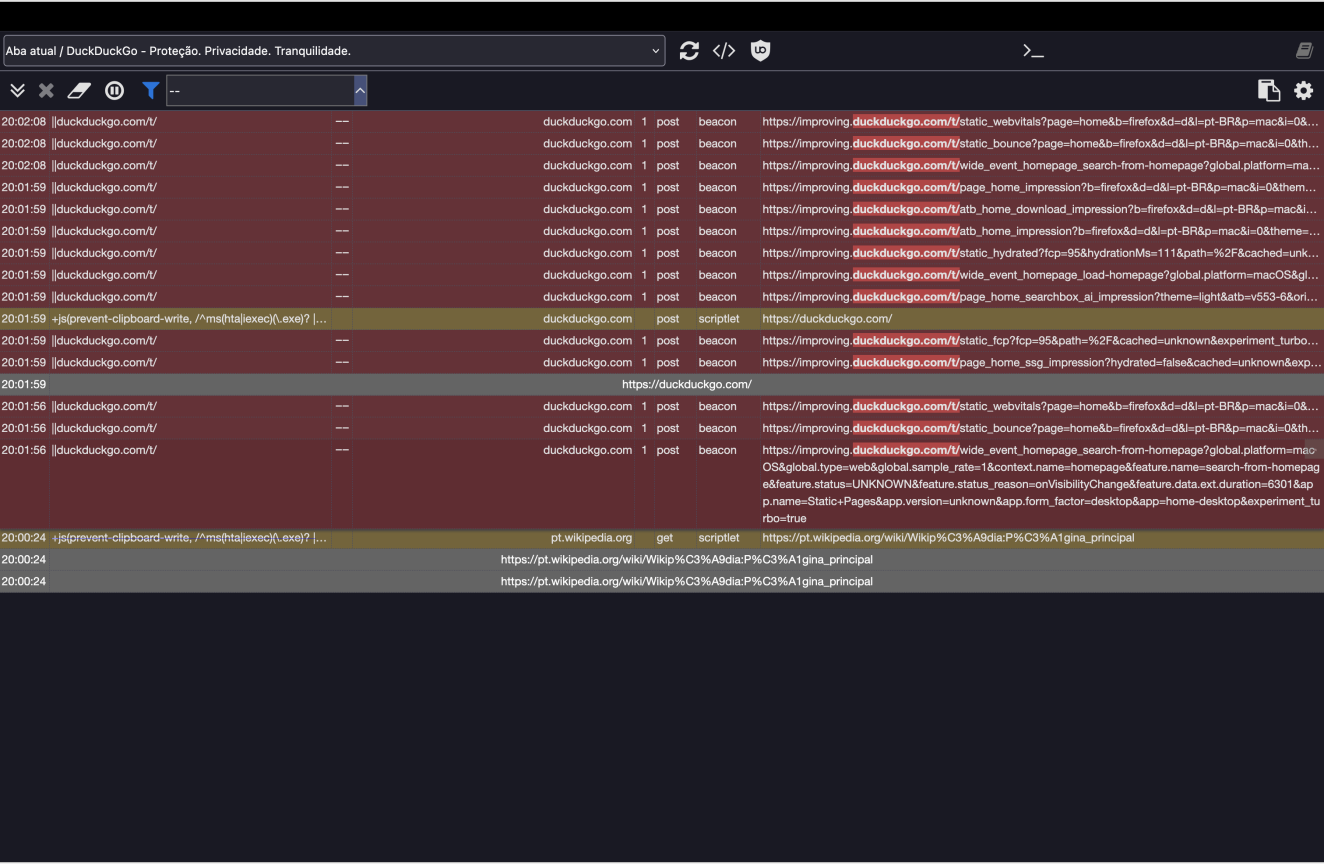


Figura 28. DuckDuckGo, registrador do uBlock filtrado pelas requisições bloqueadas

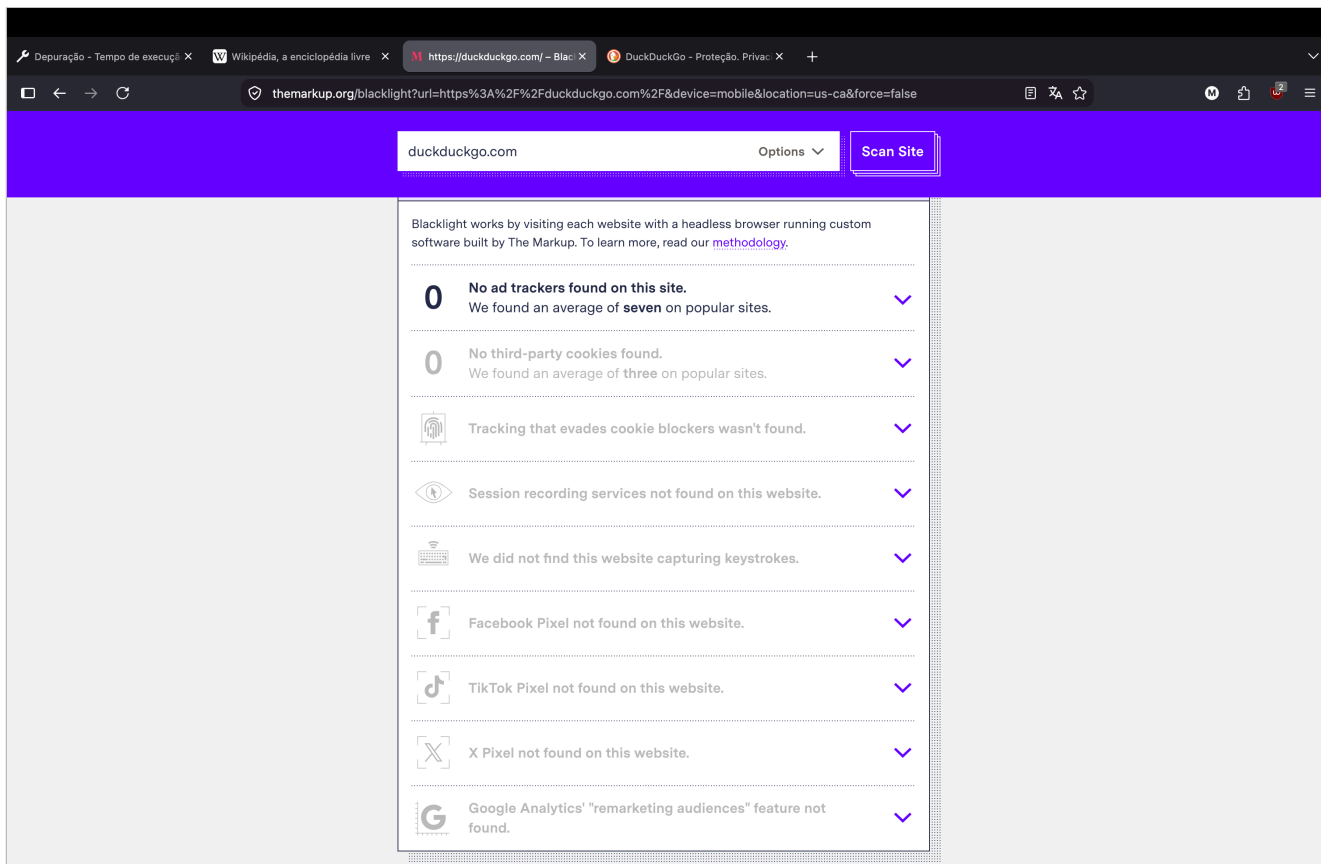


Figura 29. DuckDuckGo, Blacklight

5. Entregável 4: pontuação de privacidade

5.1 Metodologia

A página começa com 100 e perde pontos por ocorrência de cada critério, até um teto por critério, para que um único tipo de problema não zere a nota. Faixas: 80 a 100 boa, 50 a 79 moderada, abaixo de 50 ruim. Princípio dos pesos: quanto mais difícil para o usuário se defender, maior o peso; um cookie dá para apagar, um fingerprint não depende de nada gravado. Cálculo em `lib/score.js`. Um cookie de terceira parte persistente desconta nos critérios 2 e 3 de propósito: são dois riscos, o cruzamento entre sites e a permanência. O critério 6 junta bounce, sync e parâmetros porque os três servem ao mesmo fim, ligar identidades entre sites.

Critério	Desconto	Teto	Justificativa
Domínio de terceira parte	-2 cada	-30	Cada terceiro recebe IP, navegador e página visitada. Peso baixo por item porque muitos são CDN; teto alto porque dezenas de terceiros indicam ecossistema de rastreamento.
Cookie de terceira parte	-3 cada	-20	Permite ao terceiro reconhecer o usuário em sites diferentes.
Cookie persistente	-1 cada	-10	Sobrevive ao fechamento do navegador; peso baixo porque também serve a preferências legítimas.
Origem de terceira parte com armazenamento HTML5	-5 cada	-10	Outro lugar para guardar identificador, fora dos cookies e das ferramentas usuais de limpeza.
Canvas fingerprint	-20	-20	Identifica o navegador sem gravar nada; limpar cookies não resolve.
Bounce tracking, cookie sync e parâmetros de rastreo	-15	-15	Liga a identidade entre sites e contorna o particionamento de cookies.

5.2 Aplicação aos 3 sites e comparação com o Blacklight

O Blacklight não dá nota única, então a comparação é por critério: third-party cookies com o critério 2, canvas fingerprinting com o 5, ad trackers com o 1 (o Blacklight conta só rastreadores conhecidos; o plugin, todo terceiro).

Site	Nota	Descontos	Blacklight	Onde concordam e onde divergem
pt.wikipedia.org	68	1 terceiro (-2); 11 cookies de terceira parte (-20, teto); 10 persistentes (-10, teto)	0 ad trackers, 4 third-party cookies	Concordam em tudo, menos na severidade dos cookies: os 11 do plugin são 4 nomes repetidos entre hosts da própria Wikimedia (4.1). A nota 68 é dura para um site sem rastreador de anúncio, por o critério 2 contar por nome e host.

www.gov.br/pt-br	55	11 terceiros (–22); 2 cookies de terceira parte (–6); 2 persistentes (–2); cookie sync (–15)	1 ad tracker (script da Alphabet), 0 third-party cookies, remarketing não encontrado	Concordam que há rastreador de anúncio do Google antes do consentimento. Divergem nos cookies e no remarketing, provavelmente pela visita mobile do Blacklight (4.2). O critério 6 pega o que o Blacklight não mede, o cid compartilhado com DoubleClick e Google Ads, com a ressalva da seção 6.
duckduckgo.com	100	nenhum	0 em tudo	Concordância total. Só o uBlock aponta a telemetria de primeira parte, que nenhum critério cobre porque não há terceiro nem cookie (4.3). A régua separa os três sites: 100, 68 e 55.

6. Limitações

- eTLD+1 com lista de sufixos reduzida (bucket.s3.amazonaws.com vira amazonaws.com; good. e bad.third-party.site viram o mesmo site).
- cookies.onChanged não informa a aba; a atribuição é por domínio. Um cookie regravado com valor idêntico pode não gerar evento (observado no DDG e, provavelmente, na Wikipédia, seção 4.1).
- Cookie com expiração curta (NetworkProbeLimit, uma hora) conta como persistente.
- Canvas: heurística de texto ou WebGL, mínimo 16×16; não cobre workers nem createImageBitmap; outros vetores (navigator, fontes, áudio) não são monitorados.
- Bounce: a regra de 10 s pode acusar redirecionamentos legítimos, como login único; o Firefox não sinalizou client_redirect em nenhum teste.
- Cookie sync: a heurística aceita qualquer valor longo, então no gov.br lista, além do cid, parâmetros de configuração do GA4 iguais para todos (tid, gtm, gcd, tag_exp). Na prática, qualquer site com GA4 recebe –15. Melhoria: ignorar parâmetros com valor igual entre visitantes.
- A contagem de terceiros não distingue CDN, órgão do mesmo governo ou rastreador; essa distinção foi feita no relatório, com as listas do Blacklight e do uBlock. A nota também depende do momento, porque scripts tardios (GTM, Analytics) a fazem cair depois do load.
- O plugin só observa; bloqueio e lista personalizada são itens do conceito A. O popup usa textContent, nunca innerHTML.

Apêndice A. Prints complementares

Prints que sustentam contagens ou validações citadas no texto. A legenda indica a seção.

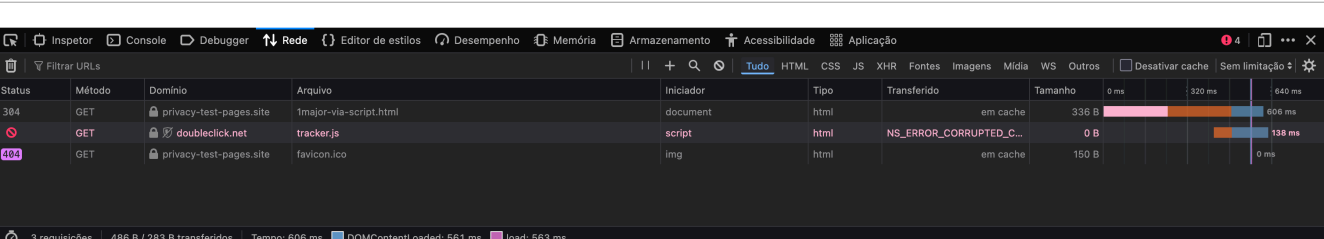


Figura 30. Seção 3.1, Tracker Reporting via script: aba Rede, a requisição a doubleclick.net/tracker.js sai e volta como html com NS_ERROR_CORRUPTED_CONTENT

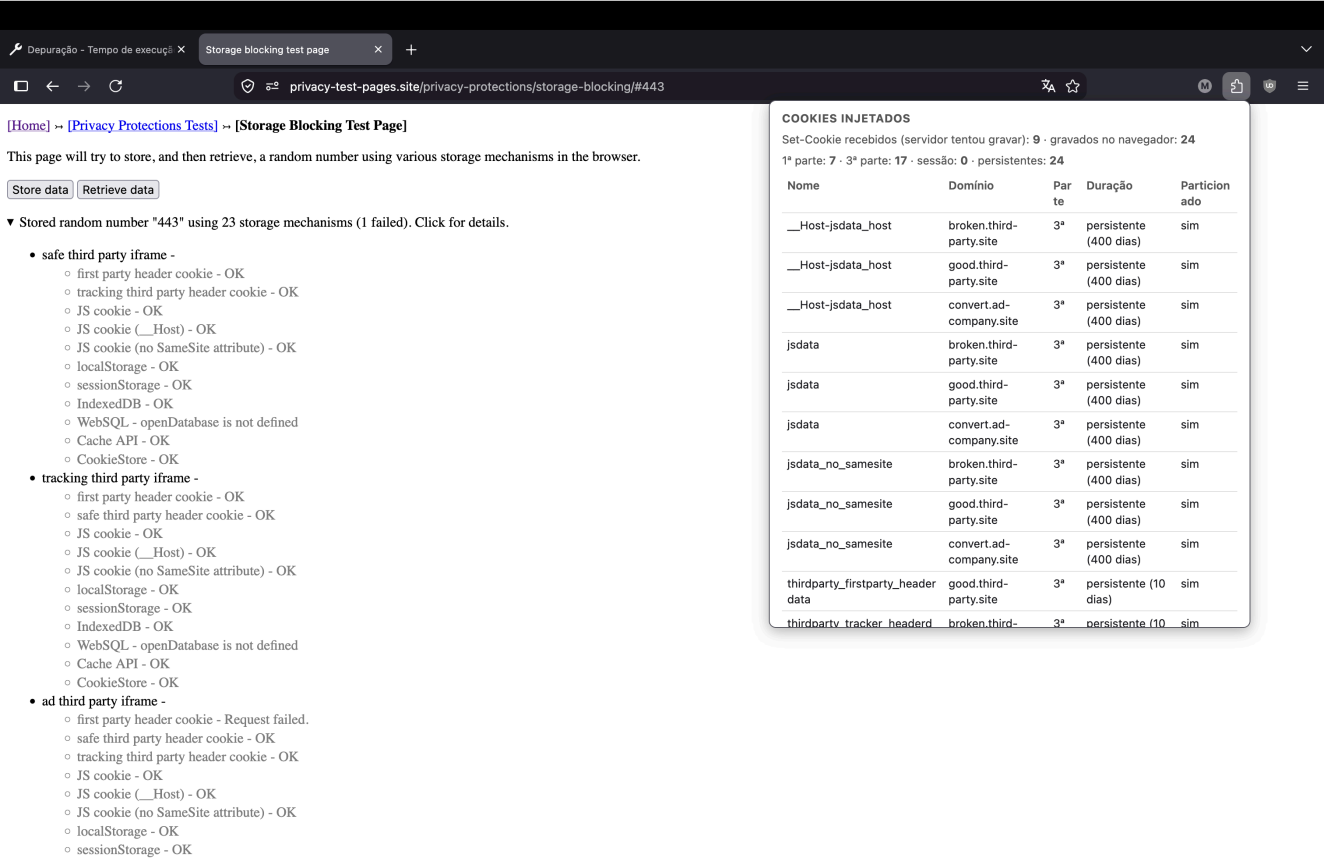


Figura 31. Seção 3.1, Storage blocking (execução 443): popup rolado, contagem e lista de cookies de terceira parte

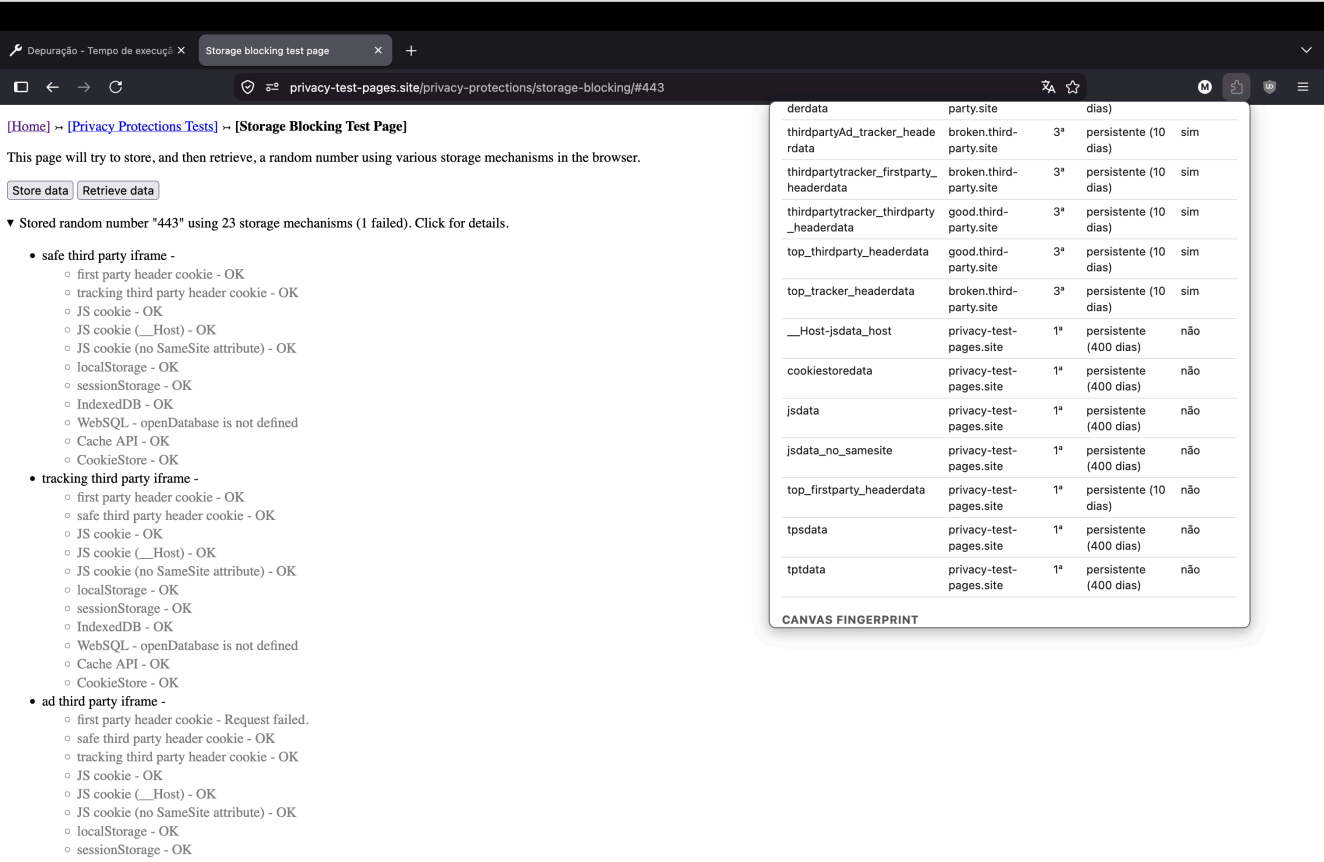


Figura 32. Seção 3.1, Storage blocking (execução 443): continuação da lista, tptdata e tpsdata como primeira parte

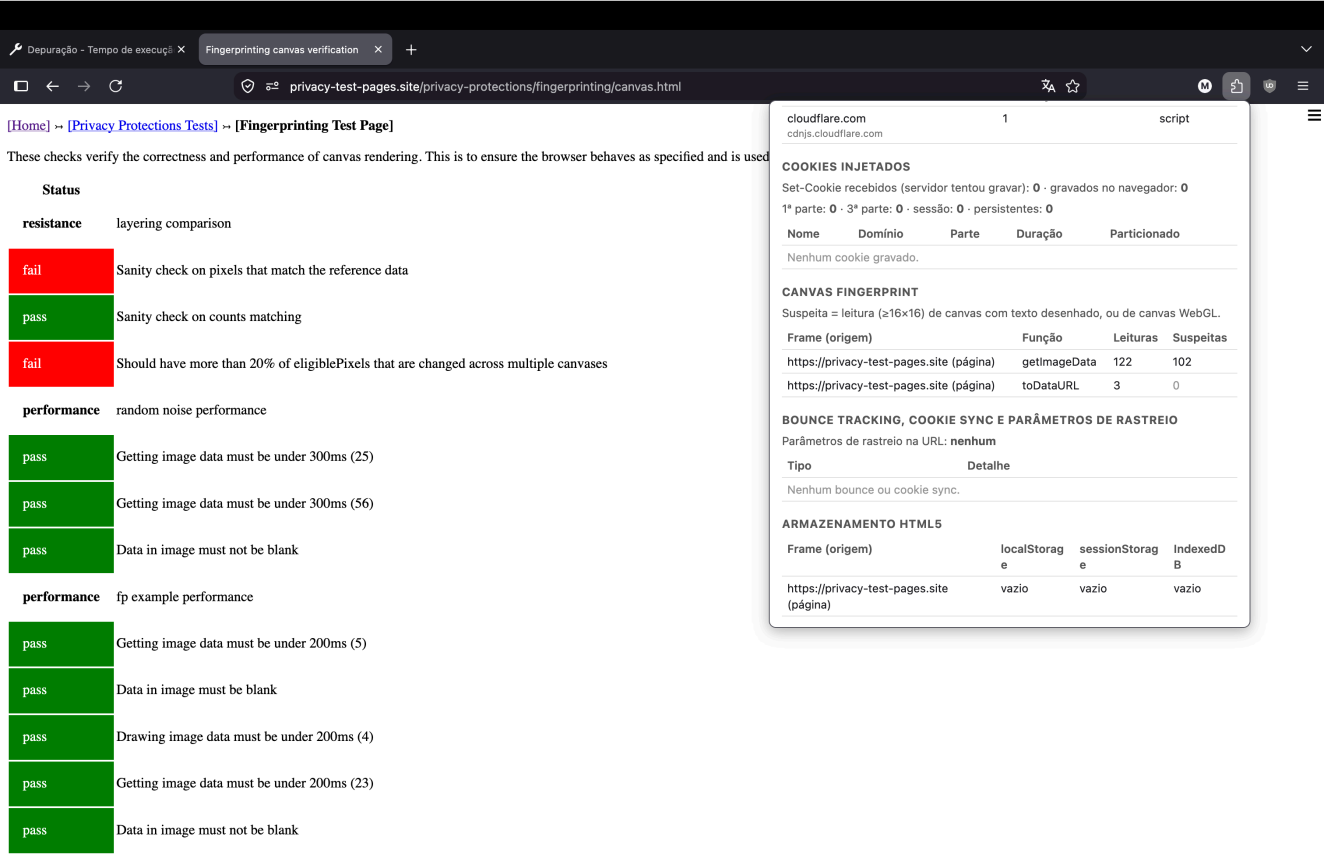


Figura 33. Seção 3.1, Fingerprinting canvas verification (execução posterior): popup rolado, getImageData 122/102 e toDataURL 3/0

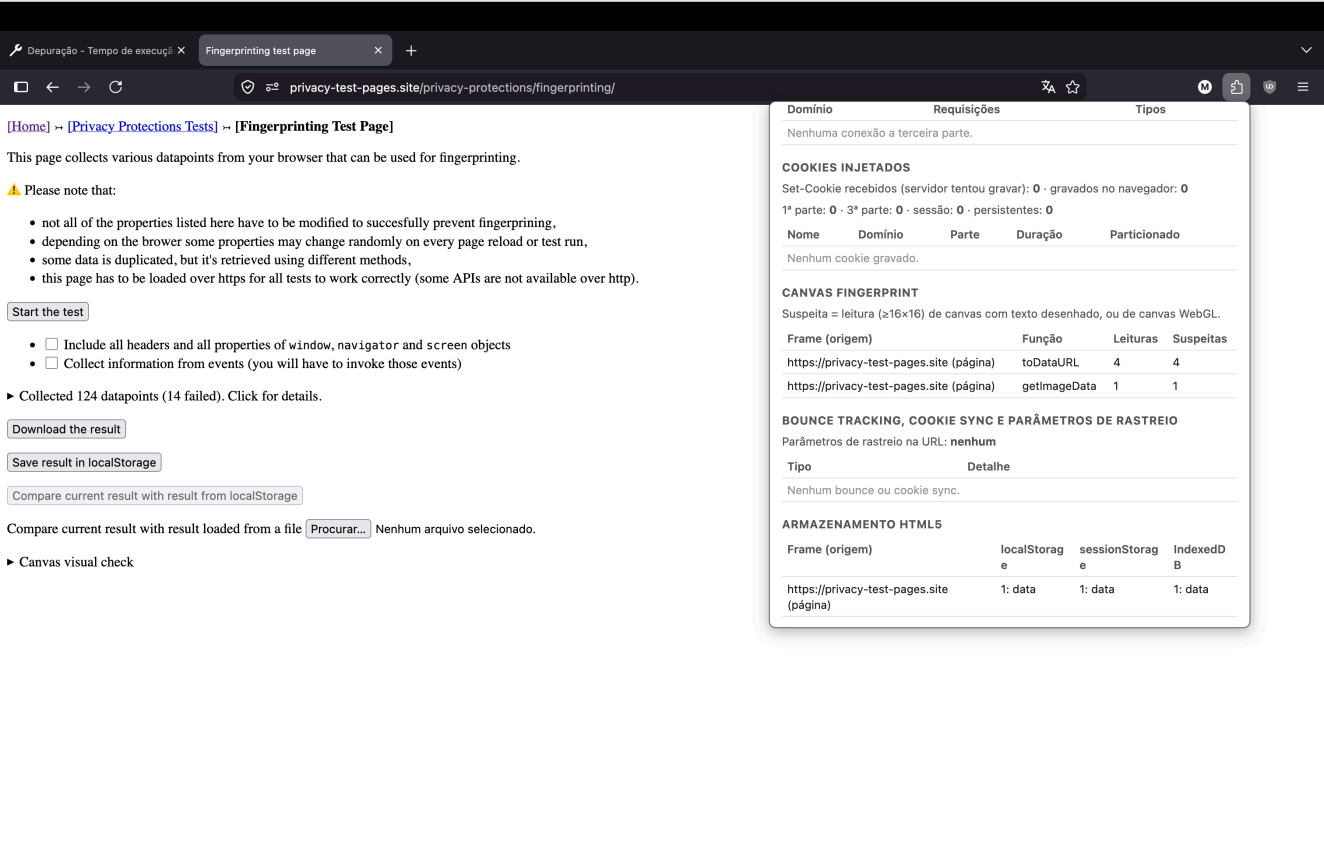


Figura 34. Seção 3.1, Fingerprinting (execução posterior): popup rolado, toDataURL 4/4 e getImageData 1/1

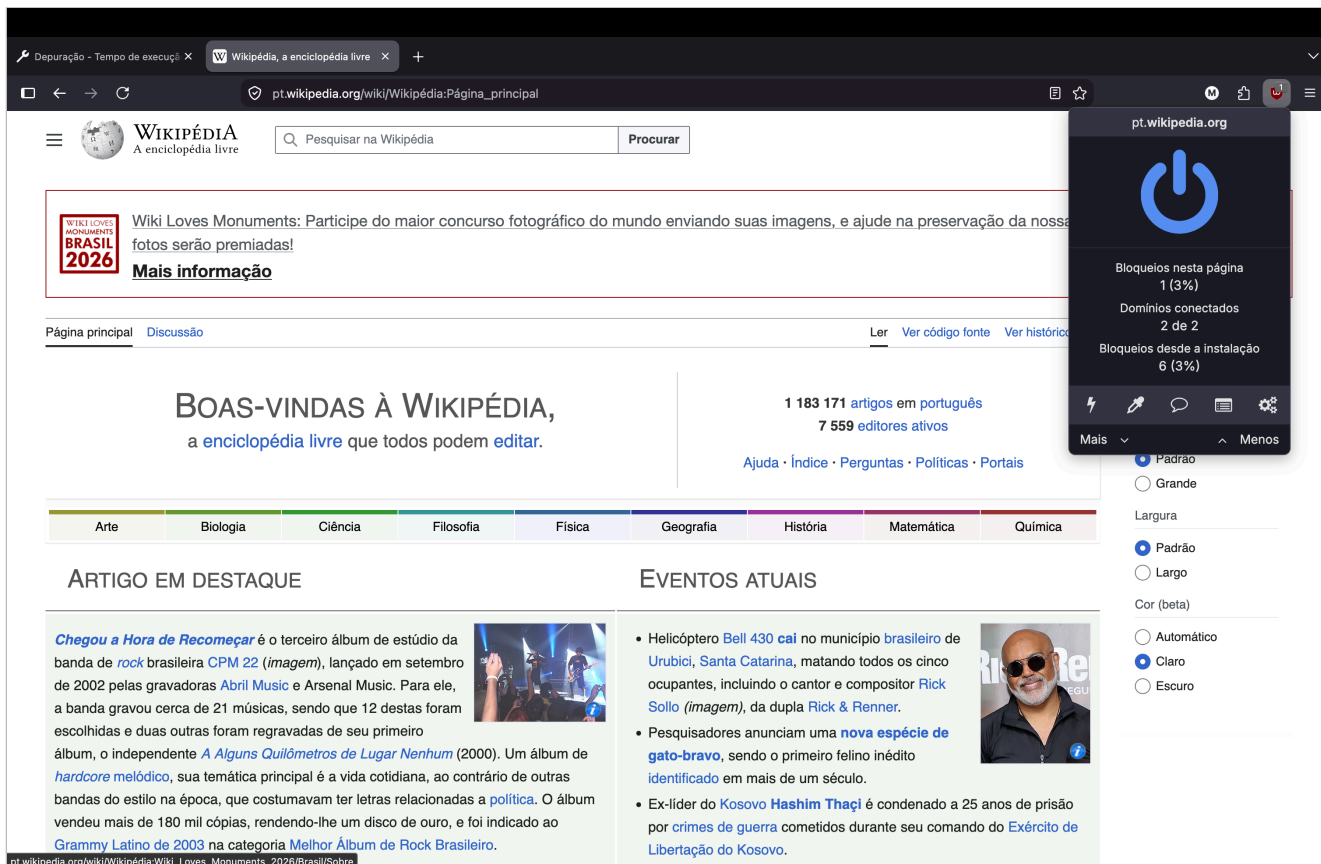


Figura 35. Seção 4.1, Wikipédia: painel do uBlock Origin

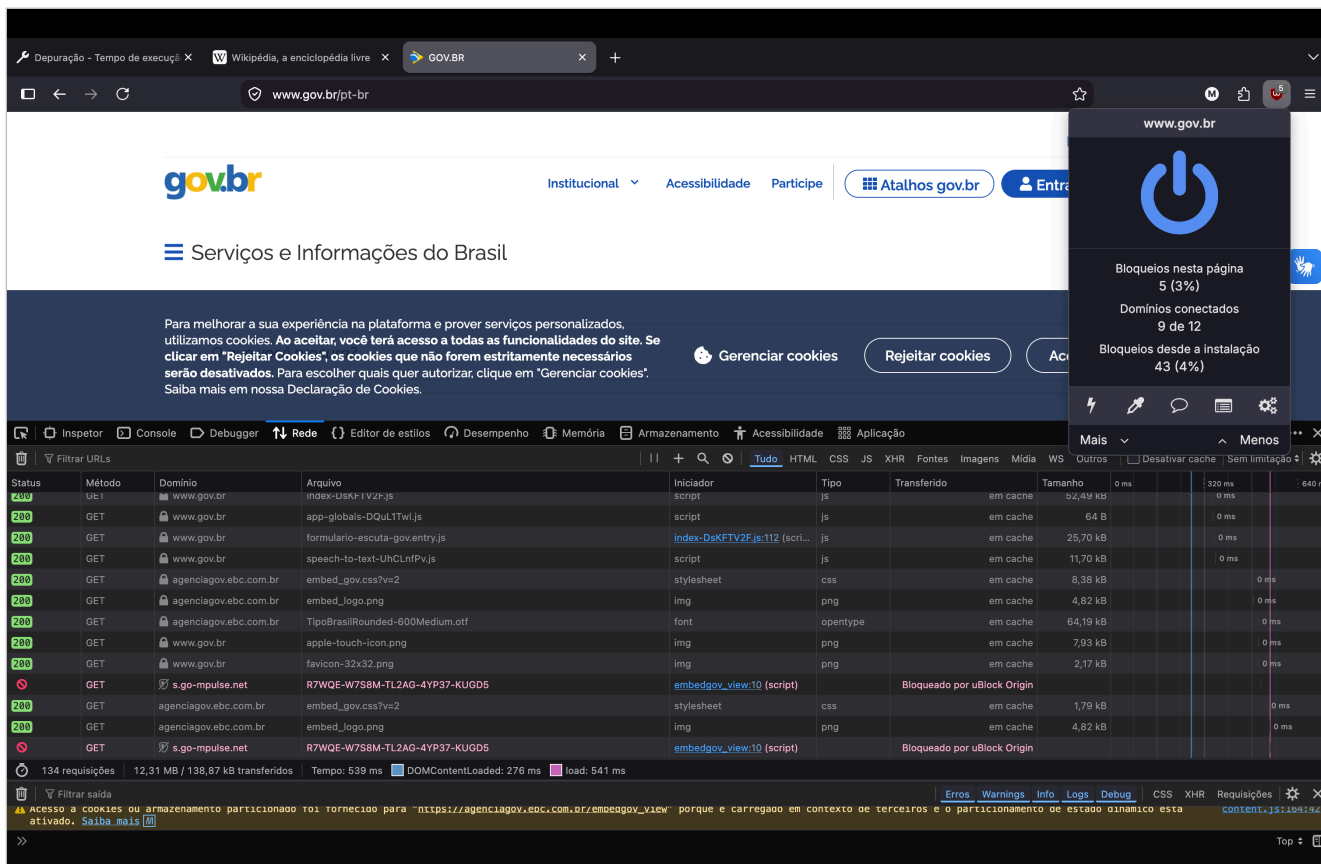


Figura 36. Seção 4.2, gov.br: painel do uBlock Origin com 5 bloqueios

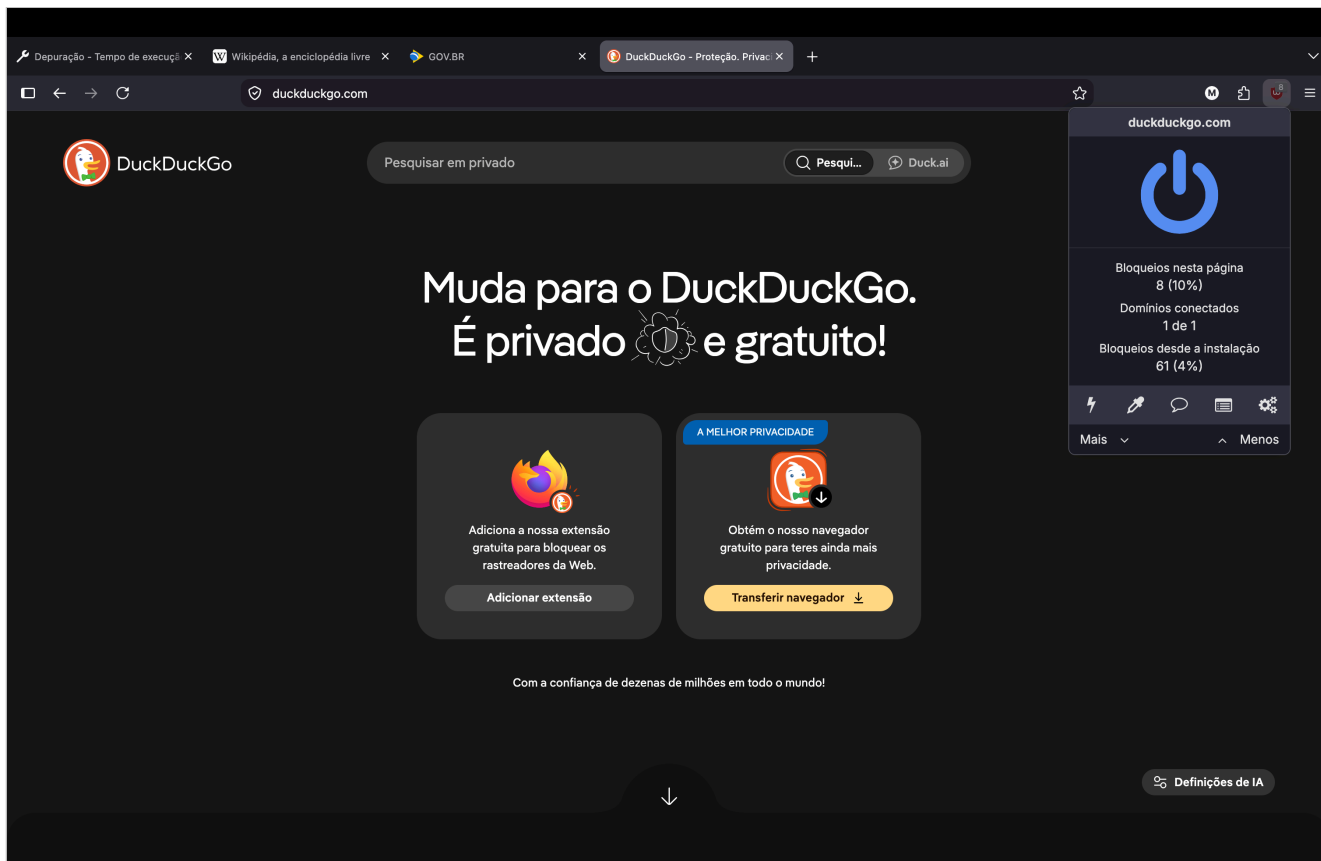


Figura 37. Seção 4.3, DuckDuckGo: painel do uBlock Origin com 8 bloqueios